

Rethinking Security Prioritization in Defender: Ranking Security Risk with Tier-Based Risk Score

Morten Knudsen

Microsoft MVP Azure, Security & Security Copilot |
Microsoft Certified Trainer

Cloud & Security Architect, freelance

Blake Cherry

Principal in Cybersecurity & Enterprise
Technology



Morten Knudsen

- ◆ Microsoft MVP Azure, Security & Security Copilot (triple-MVP)
- ◆ Freelance cloud & security architect, 2LINKIT
- ◆ Sold my 1st company (MindZet) in 2016 – 75 employees



Co-founder
Experts Live Denmark

Lead-organizer
#ELDK2025, #ELDK26



/in/knudsenmorten



@mortenknudsen.net



@knudsenmortendk



aka.ms/morten



mok@mortenknudsen.net

```
C:\Users\bcherry>whoami
Blake Cherry (@blakelishly)
Enterprise Technology Principal at West Monroe
```

Experience:
5 yrs. in consulting, focused on supporting divestitures and integrations through automation and cloud/on-premises infrastructure solutions.

Credentials:
Lead for West Monroe's greenfield environment build automation tooling.
West Monroe's Infrastructure Automation Interest Group lead.
PowerShell + DevOps Global Summit alum

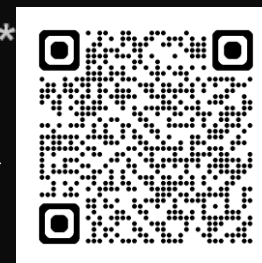
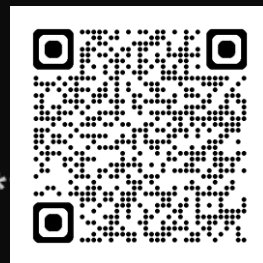


Ask Me About:

- PowerShell and Infrastructure as Code Automation
- My homelab and self-hosted services
- DevOps and Pipeline Automation
- Azure Landing Zones

Contact:

- [linkedin.com/in/rblakecherry](https://www.linkedin.com/in/rblakecherry)
- github.com/Blakelishly
- [bcherry ATSIGN westmonroe.com](mailto:bcherry@westmonroe.com)



PS C:\Users\bcherry> |



Preventative Challenges



Project (Baseline)

- M&A integration
- Baselining to 2026 level



Daily Operation (Lifecycle)

- Governance “rules”
- Processes – what, how?
- People – who?
- Responsibility & ownership



Key Challenges

- ▶ Does the business prioritize security – money, time, resources?
- ▶ “Set & forget” maturity – exceptions, push-back
- ▶ Awareness, consequences & competency – the “why?”



How many of you thinks we have too many security recommendations?

GOAL

Protect the assets that matter most
the crown jewels



DCs



OT



Break-Glass



Admin Devices



Service Accounts



Global Admins



Domain Admins

Risk-Based Approach

You can't protect everything equally → prioritize

Why SecurityInsight

FREE · COMMUNITY ADD-ON

Compliance demands risk analysis

- **NIS2 (Art. 21):** risk-management measures, asset inventory
- **DORA:** ICT risk register, criticality classification
- **ISO 27001 (A.5.9 / 8.8):** asset register + risk treatment
- **GDPR Art. 32:** risk-appropriate security of processing

Defender alone isn't enough

- **Thousands of observations** – “Set & forget”
- **No tiering** of users, devices, or workloads
- **Exposure data scattered** across tools and consoles
- **Prioritizations challenges** – crown jewels/business prioritization vs. attack paths for tenant takeover

What SecurityInsight delivers

- **Take better decisions on what to fix !**
- **Enrich data -> Risk Score, Weighted Risk Score**
- **Risk factors** amplify severity × criticality
- **Automatic Asset Profiling using Dynamic approach** – Fx Tiering based on actual permissions (no tags)
- **Can Pick up new telemetry** (e.g. IsAccountLeaked, new roles, new api permissions) without redeploy
- **AI integrated in profiling & classification**

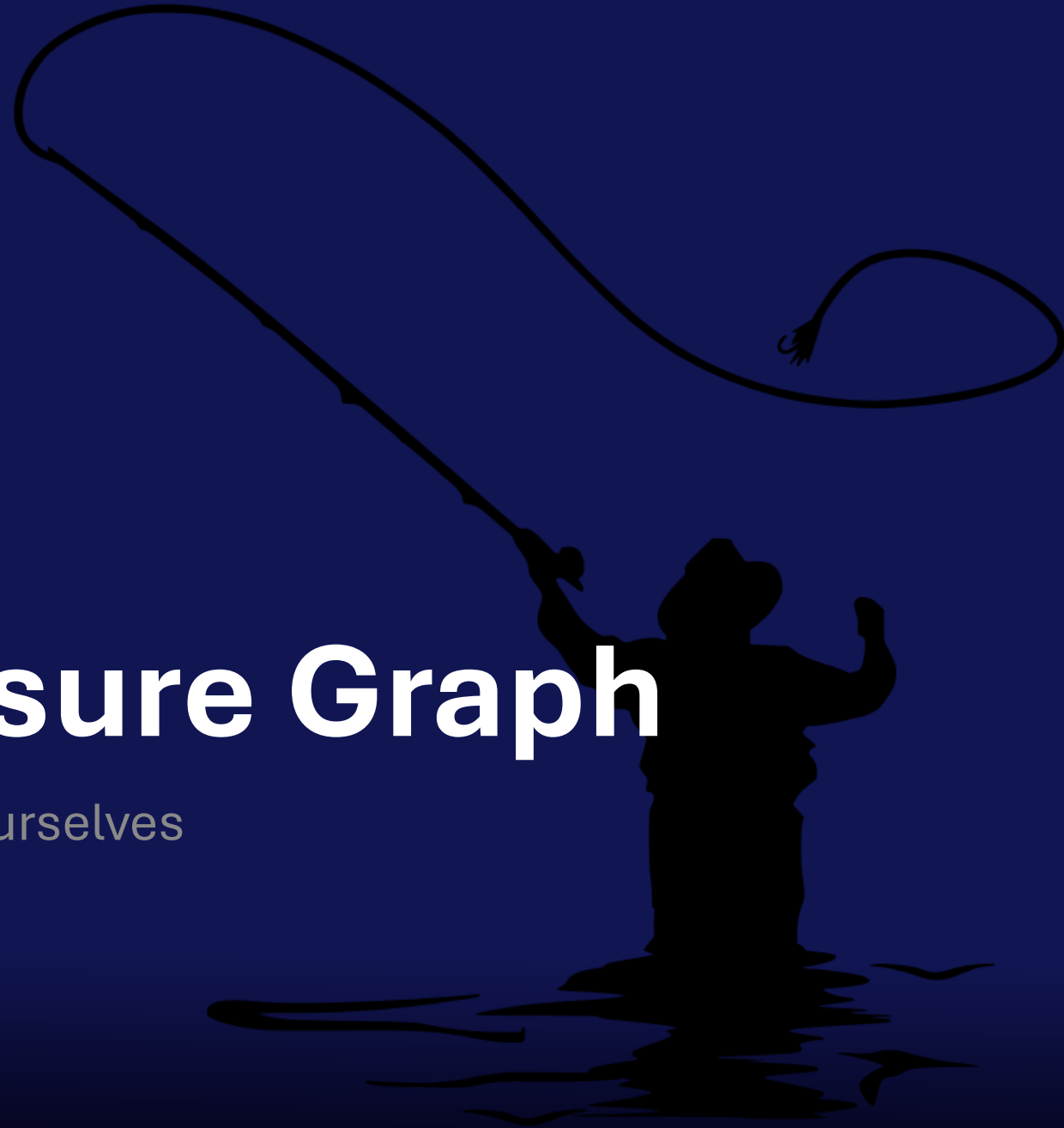
Outcomes for the business

- **Fix what matter the most** – criticality, risk, biz priority, data sensitivity
- **Detect drifts faster** - Re-focus
- **Faster audits** with traceable evidence
- **Permission snapshots** - compare 2 snapshots
- **Prioritize mini-projects** - baseline security
- **Culture** – awareness – guidance - WHY
- **Establish lifecycle processes** – who, what, when, how

1

Microsoft Exposure Graph

Why we need to use a graph to protect ourselves



Lists vs. Graphs – Why Graph is better than APIs

Same data — but only Graph answers “what actually puts us at risk?”

DIMENSION	API / LIST APPROACH	GRAPH APPROACH
Question shape	<i>“What vulnerabilities exist?”</i> Inventory mindset — count everything.	<i>“Which vulnerability lead to compromise?”</i> Path mindset — only what reaches what matters.
Data structure	Flat tables and paginated API responses — each call returns one type of object.	Nodes + edges — assets, identities, permissions and relationships in one connected model.
Correlation	You join lists by hand: vulns × hosts × users × access — hard to keep right at scale.	Relationships are first-class — “user X has access to host Y running vuln Z” is one query.
Attack paths	Invisible — multi-hop chains hide between separate API surfaces.	Native — traverse edges to find any path that reaches Tier 0 or a crown jewel.
Scales to humans?	No — nobody can hold thousands of cross-table relationships in their head.	Yes — the engine walks the graph, you read prioritized findings.
Prioritization output	Long list of findings sorted by CVSS — every defender treats the same as urgent.	Short list of findings on assets that lie on a path to something critical.

ExposureGraph

“API v2” - Index

Table: ExposureGraphNode

(normalized sources):

Devices

Users / identities

Groups

Cloud resources (VMs, storage, containers)

Applications / services

Node

Table:
ExposureGraphEdges:
“Can authenticate to”
“Has access to”
“Runs on”
“Connected to”
“Exposed to vulnerability”

Node

Node

Advanced hunting

</> New query* × </> New query × </> New query* ×

> ^ Query Run query

1 ExposureGraphNode
2 | distinct NodeLabel

Results Query history Getting started

Export Show empty columns

Filters: Add filter

☐ NodeLabel

☐ > baseModel

☐ > Cve

☐ > serviceprincipal

☐ > device

☐ > microsoft.compute/virtualmachines/extensions

☐ > user

☐ > endpointAiAgent

☐ > managedidentity

☐ > microsoft.sql/servers

☐ > entra-userCookie

☐ > Microsoft Entra OAuth App

☐ > microsoft.network/virtualnetworks/subnets

☐ > resourcegroups

☐ > group

☐ > mdcSecurityRecommendation

☐ > mdcAuditingRecommendation

☐ > mdcManagementRecommendation

☐ > mde-healthFinding

Home

Exposure management

Investigation & response

Incidents & alerts

Hunting

Advanced hunting

Custom detection rules

Actions & submissions

Partner catalog

Threat intelligence

Assets

Microsoft Sentinel

Identities

Endpoints

Email & collaboration

Cloud apps

Cloud security

Advanced hunting

</> New query* × </> New query × </> New query* ×

> ^ Query Run query

1 ExposureGraphEdges
2 | distinct EdgeLabel

Results Query history Getting started

Export Show empty columns

Filters: Add filter

☐ EdgeLabel

☐ > contains

☐ > affecting

☐ > has role on

☐ > has credentials of

☐ > has permissions to

☐ > can authenticate as

☐ > routes traffic to

☐ > member of

☐ > frequently logged in

☐ > can authenticate to

☐ > defined in

☐ > defines

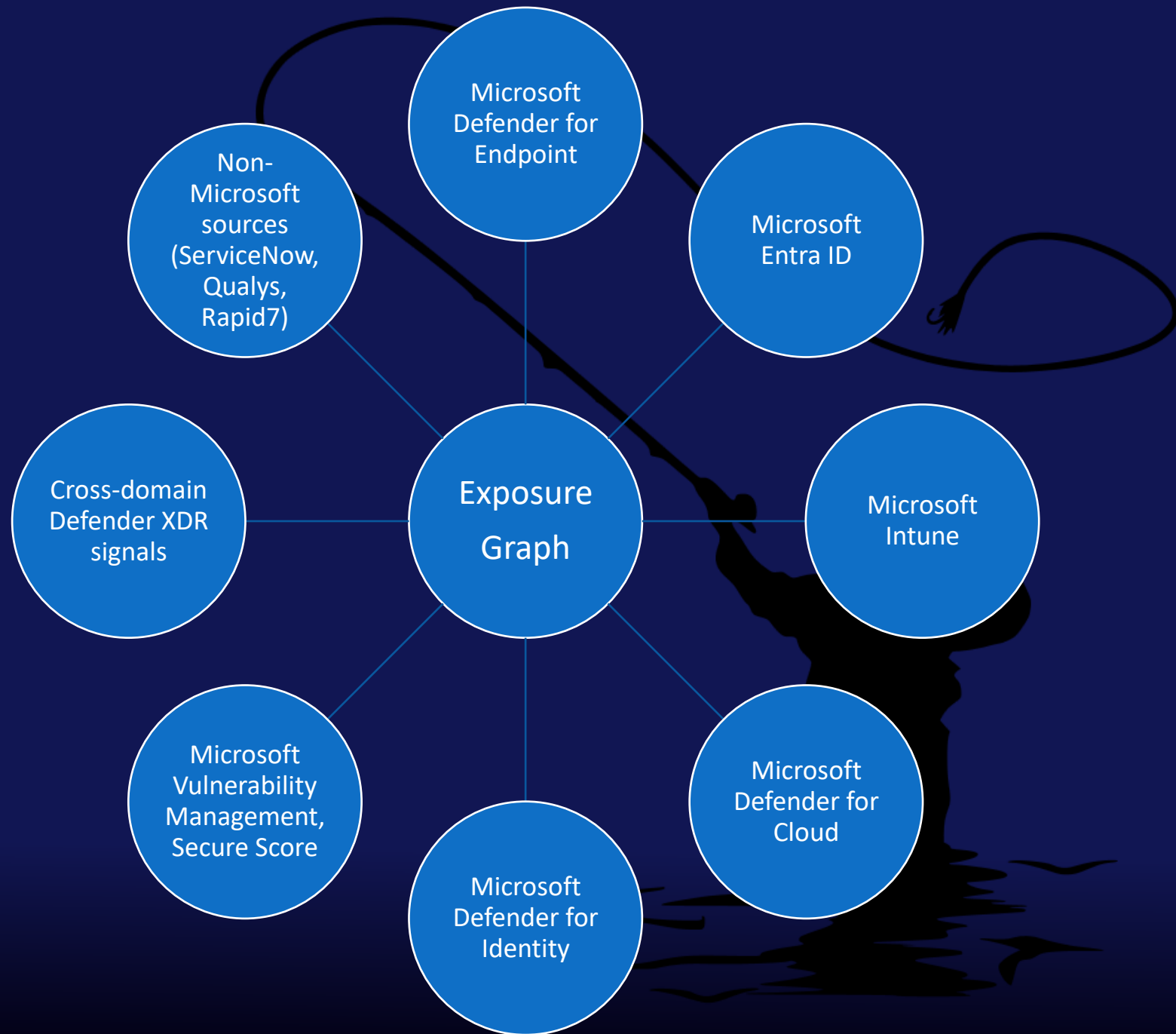
☐ > can impersonate as

☐ > runs on

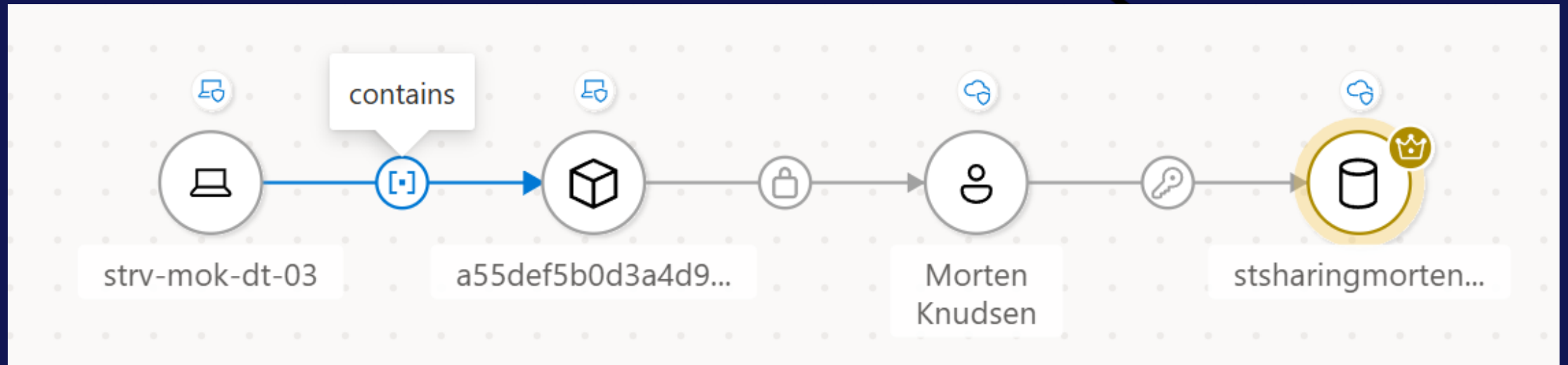


ExposureGraph

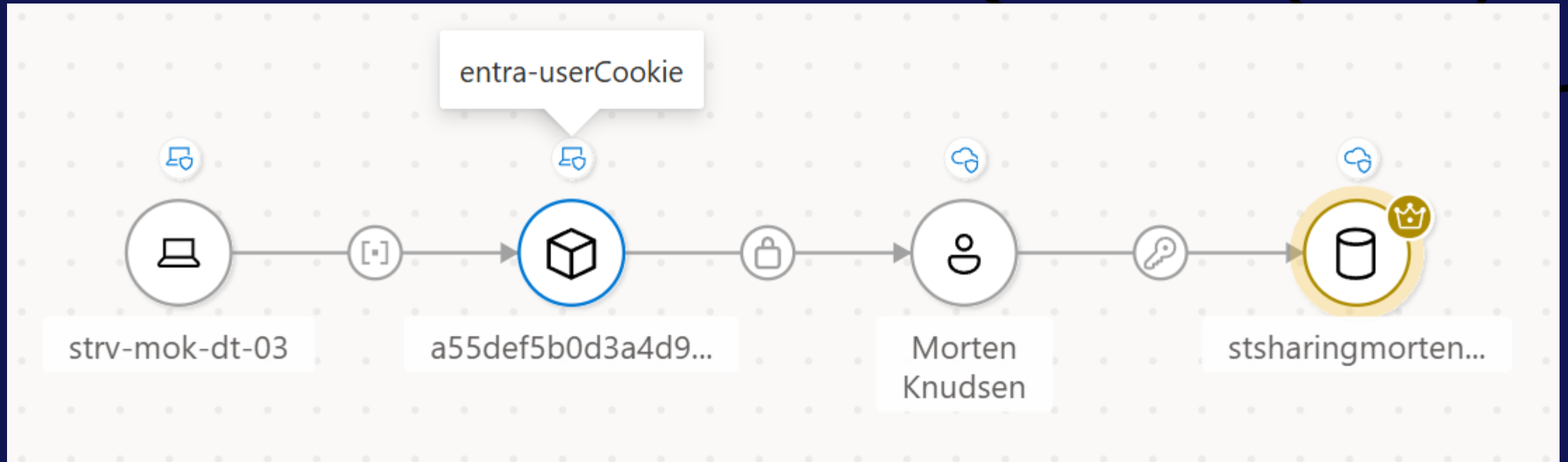
Data sources



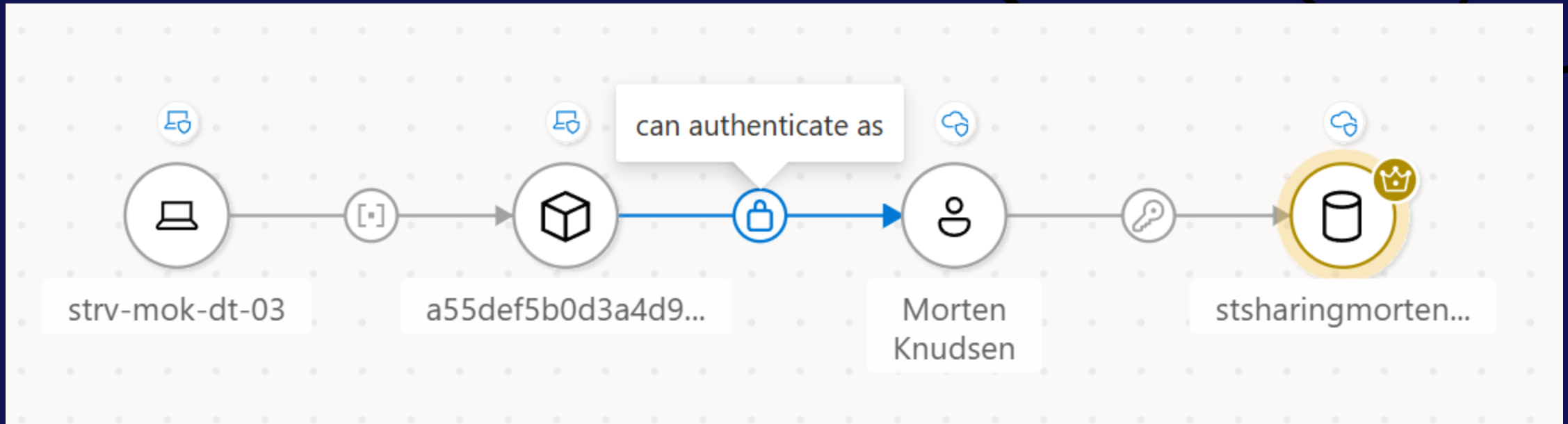
Example of Attack Path



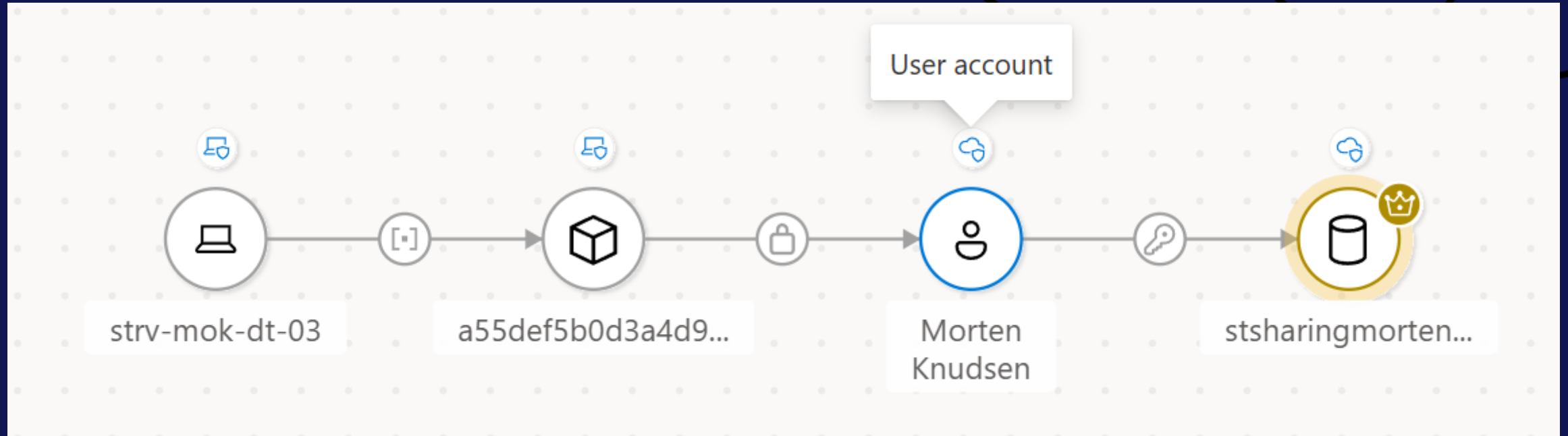
Example of Attack Path



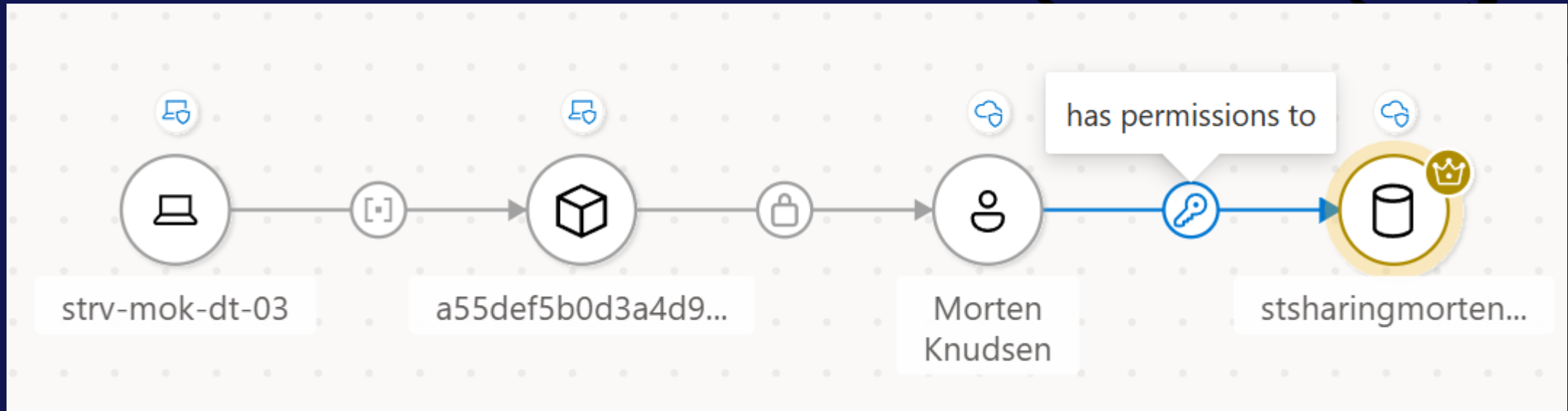
Example of Attack Path



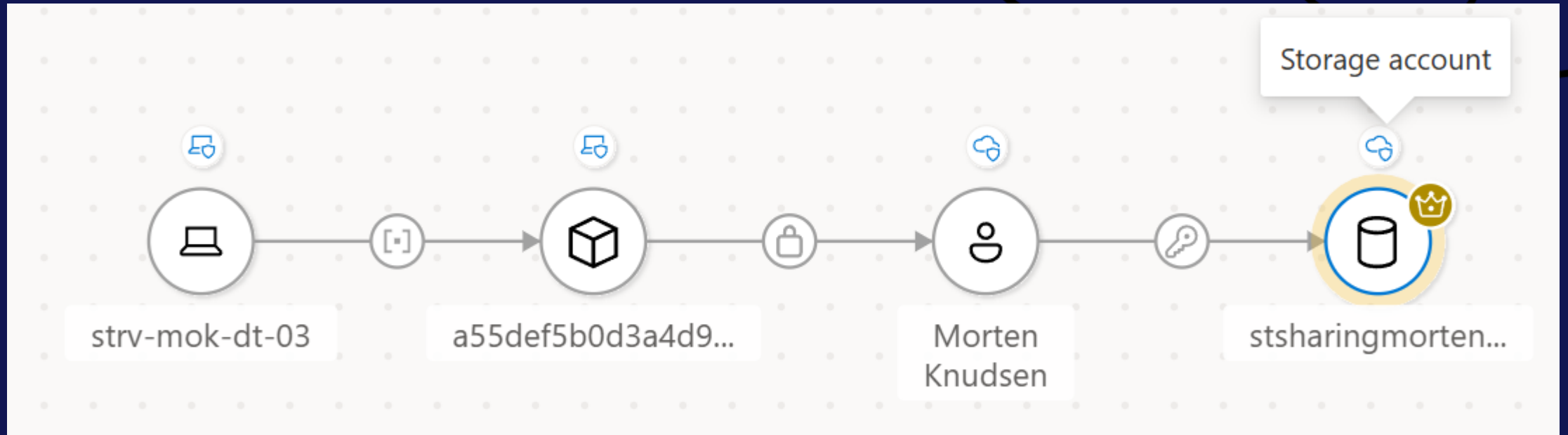
Example of Attack Path



Example of Attack Path



Example of Attack Path



Find all DC & DNS resources

ExposureGraphNode

| where NodeLabel has "device"

or NodeLabel has "microsoft.compute/virtualmachines"

or NodeLabel has "microsoft.hybridcompute/machines"

| extend rawData = todynamic(NodeProperties).rawData

| where tobool(rawData.isExcluded) == false

| where toString(rawData.deviceType) == "Server"

| where tolower(toString(rawData.onboardingStatus)) == "onboarded"

| project NodeId, NodeName, NodeLabel, rawData, EntityIds

| extend

confidenceHigh = iff(isnull(rawData.criticalityConfidenceHigh), dynamic([]), todynamic(rawData.criticalityConfidenceHigh)),

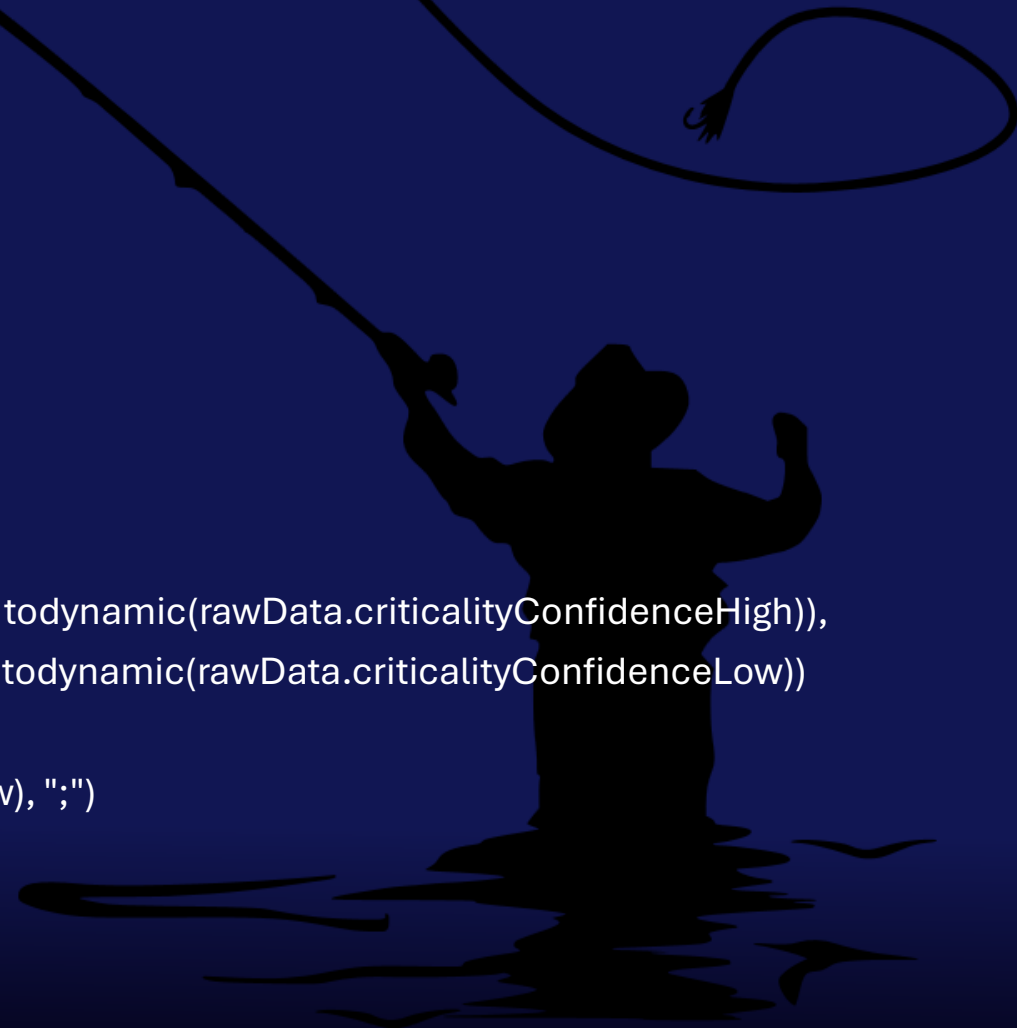
confidenceLow = iff(isnull(rawData.criticalityConfidenceLow), dynamic([]), todynamic(rawData.criticalityConfidenceLow))

| extend

DetectedRoles = strcat_array(array_concat(confidenceHigh, confidenceLow), ";")

| where DetectedRoles has "DomainController"

or DetectedRoles has "Dns"



Find all DC & DNS resources

ExposureGraphNode

| where NodeLabel has "device"

or NodeLabel has "microsoft.compute/virtualmachines"

or NodeLabel has "microsoft.hybridcompute/machines"

| extend rawData = todynamic(NodeProperties).rawData

| where tobool(rawData.isExcluded) == false

| where toString(rawData.deviceType) == "Server"

| where tolower(toString(rawData.onboardingStatus)) == "onboarded"

| project NodeId, NodeName, NodeLabel, rawData, EntityIds

| extend

confidenceHigh = iff(isnull(rawData.criticalityConfidenceHigh), dynamic([]), todynamic(rawData.criticalityConfidenceHigh)),

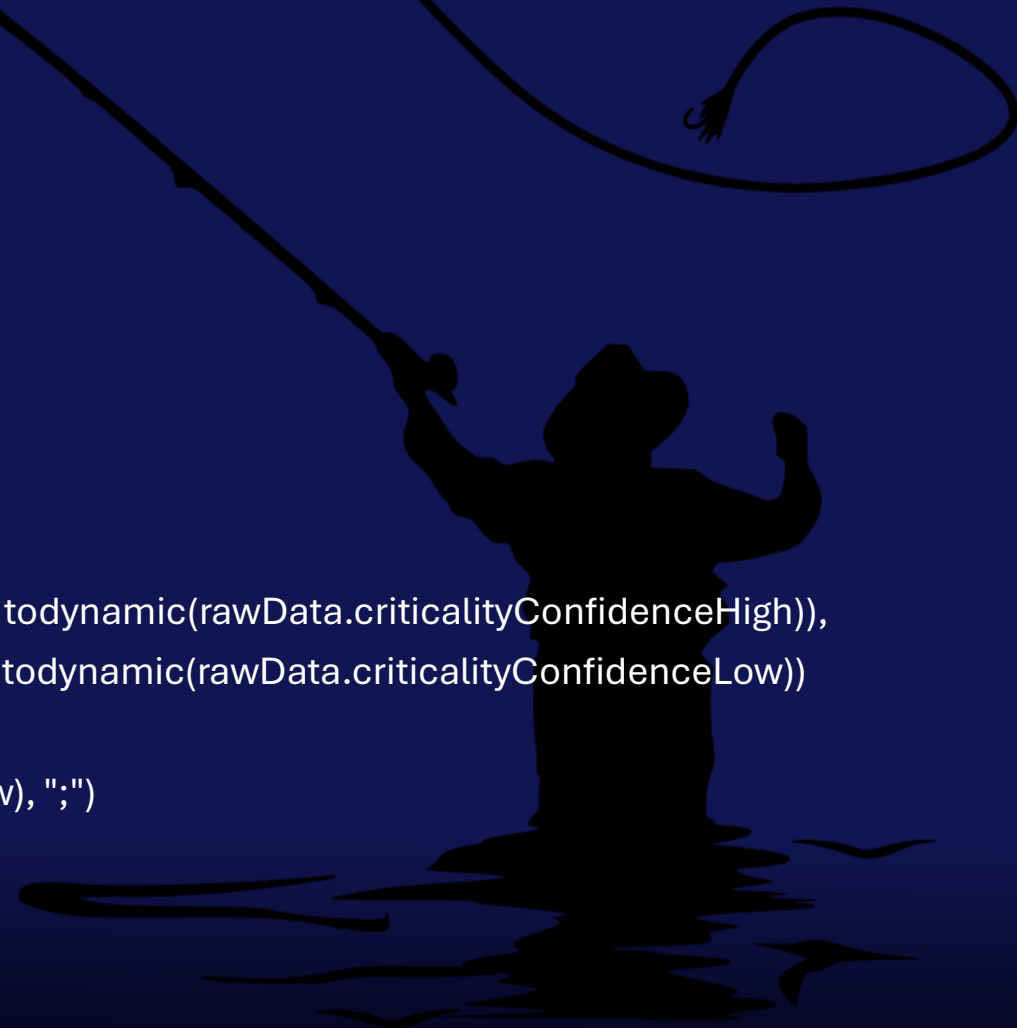
confidenceLow = iff(isnull(rawData.criticalityConfidenceLow), dynamic([]), todynamic(rawData.criticalityConfidenceLow))

| extend

DetectedRoles = strcat_array(array_concat(confidenceHigh, confidenceLow), ";")

| where DetectedRoles has "DomainController"

or DetectedRoles has "Dns"



Find all DC & DNS resources

ExposureGraphNode

| where NodeLabel has "device"

or NodeLabel has "microsoft.compute/virtualmachines"

or NodeLabel has "microsoft.hybridcompute/machines"

| extend rawData = todynamic(NodeProperties).rawData

| where tobool(rawData.isExcluded) == false

| where toString(rawData.deviceType) == "Server"

| where tolower(toString(rawData.onboardingStatus)) == "onboarded"

| project NodeId, NodeName, NodeLabel, rawData, EntityIds

| extend

confidenceHigh = iff(isnull(rawData.criticalityConfidenceHigh), dynamic([]), todynamic(rawData.criticalityConfidenceHigh)),

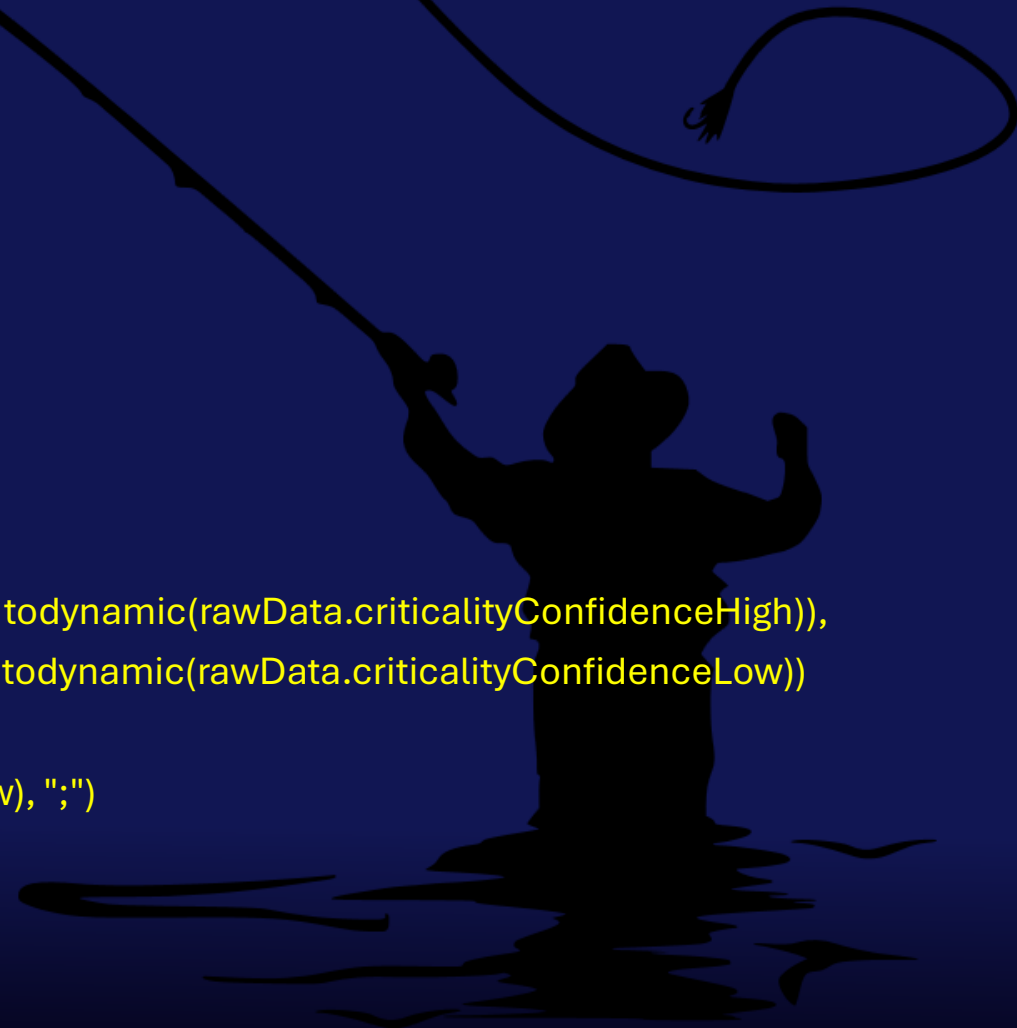
confidenceLow = iff(isnull(rawData.criticalityConfidenceLow), dynamic([]), todynamic(rawData.criticalityConfidenceLow))

| extend

DetectedRoles = strcat_array(array_concat(confidenceHigh, confidenceLow), ";")

| where DetectedRoles has "DomainController"

or DetectedRoles has "Dns"



Find all DC & DNS resources

ExposureGraphNode

| where NodeLabel has "device"

or NodeLabel has "microsoft.compute/virtualmachines"

or NodeLabel has "microsoft.hybridcompute/machines"

| extend rawData = todynamic(NodeProperties).rawData

| where tobool(rawData.isExcluded) == false

| where toString(rawData.deviceType) == "Server"

| where tolower(toString(rawData.onboardingStatus)) == "onboarded"

| project NodeId, NodeName, NodeLabel, rawData, EntityIds

| extend

confidenceHigh = iff(isnull(rawData.criticalityConfidenceHigh), dynamic([]), todynamic(rawData.criticalityConfidenceHigh)),

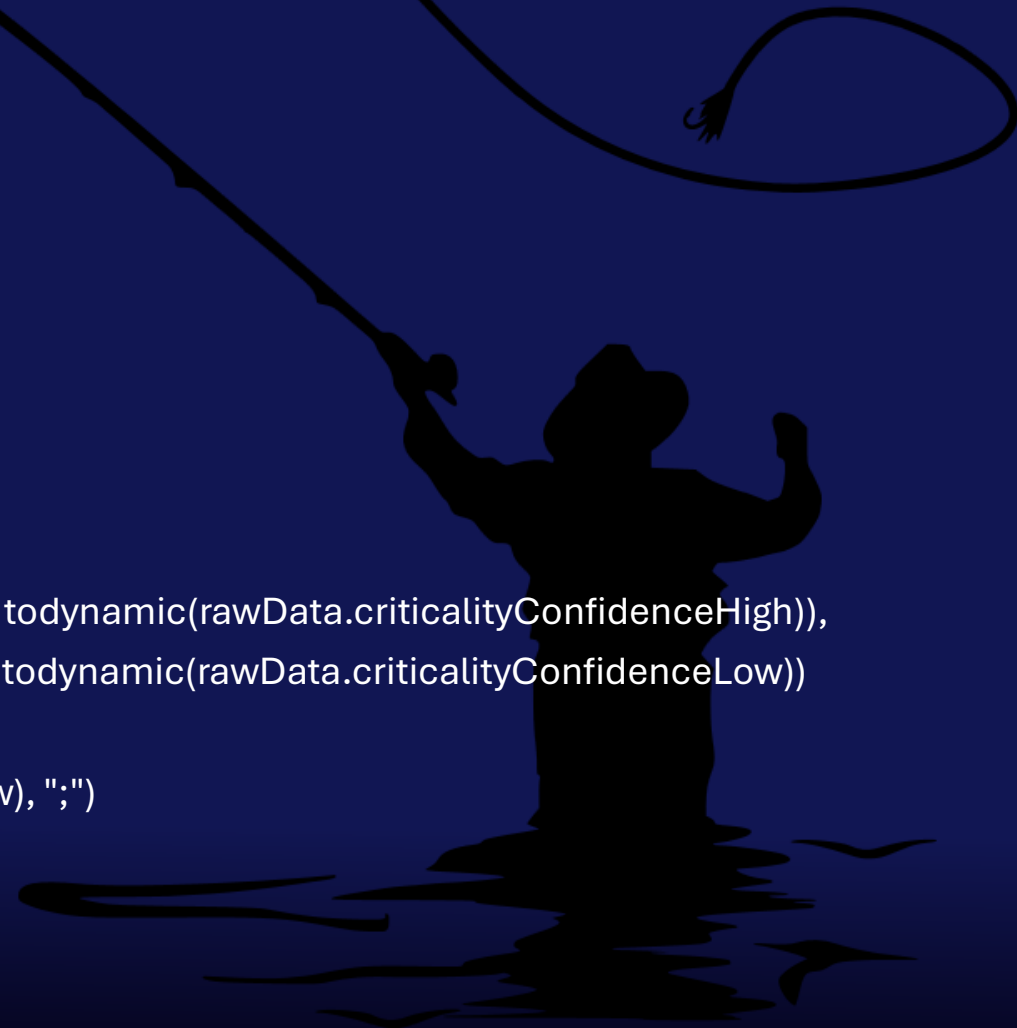
confidenceLow = iff(isnull(rawData.criticalityConfidenceLow), dynamic([]), todynamic(rawData.criticalityConfidenceLow))

| extend

DetectedRoles = strcat_array(array_concat(confidenceHigh, confidenceLow), ";")

| where DetectedRoles has "DomainController"

or DetectedRoles has "Dns"



2

Risk-based Approach

We need to enrich data with tier & business classification & risk factors = Risk Score
Result: We can take better decisions on what to first before others !!

SecurityInsight



Sample: Tiering of Client Devices by Risk – *Supported by SecurityInsight*

TIER 3

Receptionist

STANDARD • Risk



- Shared / kiosk-style use
- No admin rights anywhere
- No access to crown-jewel data
- Compromise impact: limited to one mailbox

TIER 2

HR / Finance

ELEVATED • Risk



- Daily access to PII, payroll, contracts
- Authorized signers in finance systems
- Compromise impact: data exfil + fraud
- Compliance & breach-disclosure exposure

TIER 1

IT / Developer

PRIVILEGED • Risk



- Local admin, prod credentials, secrets
- Source code, CI/CD, deployment pipelines
- Lateral path to Tier 0 (DCs, key vaults)
- Compromise impact: enterprise-wide

SecurityInsight Risk Score Formula

Severity × Criticality, with risk factors as +1 modifiers

SEVERITY (+ RISK FACTORS)

consequence × risk modifiers

×

CRITICALITY (+ RISK FACTORS)

asset value × risk modifiers

=

RISK SCORE

Risk factors → +1 to severity / criticality (per applicable factor)

Internet

Verified Secret

Critical Resource

Lateral

Sensitive Data

Exploit Available

Critical CVE on
internet-facing prod
server, ExploitKit
found

$$\left(\begin{array}{|c|} \hline 4 \\ \hline \end{array} + \begin{array}{|c|} \hline 1 \\ \hline \end{array} \right) \times \left(\begin{array}{|c|} \hline 4 \\ \hline \end{array} + \begin{array}{|c|} \hline 1 \\ \hline \end{array} \right) = \begin{array}{|c|} \hline 25 \\ \hline \end{array}$$

$(4 + 1) \times (4 + 1) = 25$

Medium CVE on
a standard
workstation

$$\left(\begin{array}{|c|} \hline 2 \\ \hline \end{array} + \begin{array}{|c|} \hline 0 \\ \hline \end{array} \right) \times \left(\begin{array}{|c|} \hline 2 \\ \hline \end{array} + \begin{array}{|c|} \hline 0 \\ \hline \end{array} \right) = \begin{array}{|c|} \hline 4 \\ \hline \end{array}$$

$(2 + 0) \times (2 + 0) = 4$

Risk Score in Action: Prioritization Ranking

Six findings, sorted by risk score — highest = fix first

RANK	FINDING	SEVERITY +RF	CRITICALITY +RF	RISK SCORE
1	Critical CVE on internet-facing prod server, ExploitKit found	4 + +1	4 + +1	= 25
2	MFA disabled for Global Admins on identities with sensitive role	4 + 0	4 + +1	= 20
3	ASR rule "Block LSASS credential theft" not enforced on domain controllers	3 + 0	4 + +1	= 15
4	Critical CVE on internet-facing app, no compensating controls	4 + 0	3 + 0	= 12
5	47 enabled accounts with no logon for 365+ days	3 + 0	2 + 0	= 6
6	ASR rule "Block Office child processes" in audit-only on workstations	2 + 0	2 + 0	= 4

DEMO

Risk Analysis Report

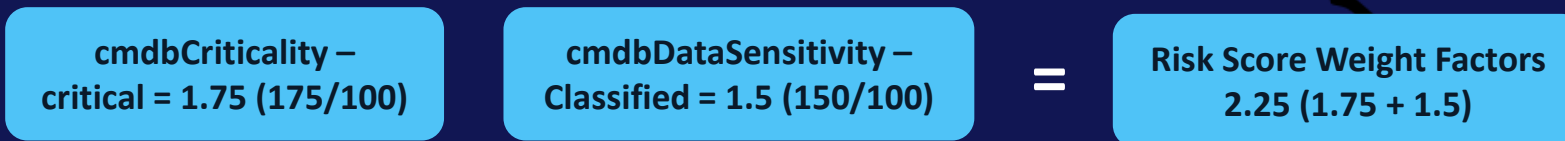
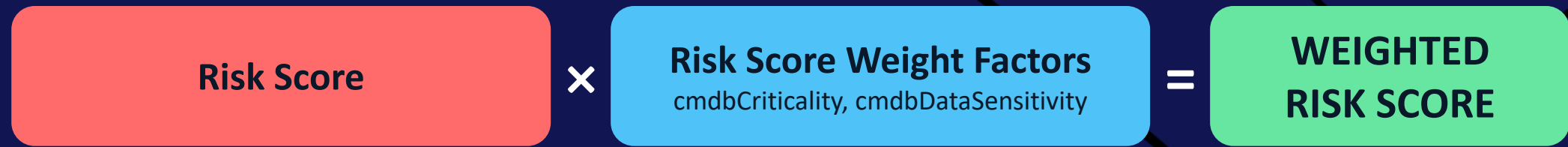
Summary

Detailed

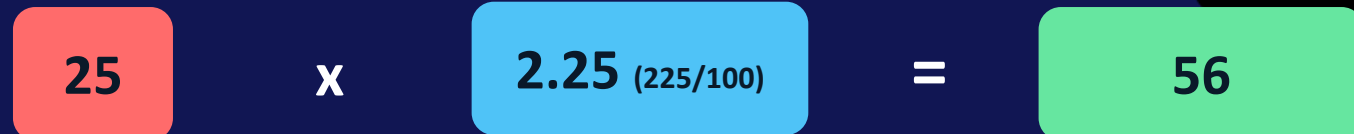


Risk Score Formula with Weight **(new)**

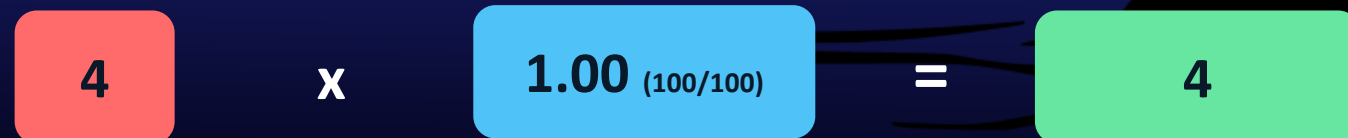
Risk Score + Weight factors = Weighted Risk score (Business Prioritization - CMDB)



Critical CVE on internet-facing prod server, ExploitKit found



Medium CVE on a standard workstation



SecurityInsight v2.2 *(new)*

Tier-aware asset risk profiling across identities, endpoints, Azure resources & internet-exposed IPs

ZERO FOOTPRINT

No agents. No writes.

Pure read-only of existing Microsoft telemetry - no agents, no tags pushed, no MDE / Entra / ARM writes.

Enriched data is captured in LogAnalytics tables (snapshot)

AUTOMATIC ENRICHMENT

Dynamic Risk-approach

Tier 0–3 per asset via **weighted multi-signal aggregator**

CMDB integration

Identity · permissions

Endpoint · logons +

500 known apps

Azure · hierarchy, tags

Public IP · exposure + CVEs (Shodan)

SCALING

Scale-up/out Throttling/Retry

Containers 1:N (KEDA)

Buckets

Hash Bucketing

Shard sizing

KEDA Queue Auto-Scale

Fingerprint caching

Tier Schedules

ORCHESTRATOR

Per-engine schema + classifier

Schema files:

Fields (included)

Detection Rules

Excluded Config Ids

Excluded CVEs

+ many more

YAML:

Reports (queries)

Profile every asset

Asset Profiling

WHAT IT DOES

Discovers every endpoint + identity across **MS365, Azure, Entra, Defender**. Pulls metadata + posture proofs, uses **AI** to assign **tier (TO-TE)**, service-type, grouping. Per-asset snapshot.

OUTPUT (LOGANALYTICS)

SI_Endpoint_Profile_CL
SI_Identity_Profile_CL
SI_Azure_Profile_CL
SI_PublicIP_Profile_CL

INDUSTRY NAMING

CAASM Cyber Asset Attack Surface Mgmt

Prioritize every risk

Risk Analysis

WHAT IT DOES

Consumes the profiled assets, runs **threat / vulnerability / exposure analyses** → produces **actionable risk findings per asset, prioritised by tier**.

OUTPUTS

SI_RiskAnalysis_Summary/Detailed_CL
Power BI dashboards, Workbooks, AI Agents

INDUSTRY NAMING

CTEM Continuous Threat Exposure Mgmt

RiskIndex - Tuning Priority to Your Environment

YOUR TUNING

MATCH KEY

CONSEQUENCE

ON TIER-0 ASSET

PRIORITY

Accept default

no row added — use baseline severity × tier

—

4

Very High

4

Critical

16

BASELINE

Boost a category

Endpoint › Security controls matters more here

Category

5

lifted +1

4

Critical

20

PROMOTED

Deprioritize on tier-3

scid-2001 EDR sensor data — fine on a kiosk

scid-2001

2

lowered

1

tier-3

2

DEPRIORITIZED

3

Asset Profiling

Posture Assessment



SecurityInsight Asset Profiling

1. Schedule

Decide if it's time to run.

- **Tier-driven cadence** — T0 every 12h, T1 daily, T2 every 3 days, T3 weekly, TE monthly.
- **Pre-flight check** — verifies SPN, OpenAI and Log Analytics connectivity.

2. Discover

Find every asset, everywhere.

- **Multi-source enumeration** — ARG, Exposure Graph, Entra and Defender, deduped.
- **Endpoints + identities** — every device, user and service principal in scope.

3. Collect

Pull just enough metadata.

- **Per-asset facts** — OS, network, owner, MachineGroup, exposure properties.
- **Change-only** — fingerprints flag what's different since the last run.

4. Analyze

Match assets to known patterns.

- **Pattern library** — Exchange, DC, web app, file server, break-glass and more.
- **Evidence, not guesses** — every match emits a labelled proof with a weight.

5. Classify

Let AI label what humans can't.

- **Tier verdicts** — T0–TE plus service type and grouping, with explainable proofs.
- **Cost-capped** — per-run AI spend ceiling keeps the bill predictable.

6. Output / Distribute

Send results where they're useful.

- **Multi-sink** — Log Analytics future: graph via Microsoft Fabric Eventhouse.
- **Snapshot per run** — every classification change has a full audit trail.

Endpoint Classification

*Tier inherits from frequent-logon users — devices are as risky as the people who use them
+ other signals (fields, software mapping, tags match, etc.)*

Tier	Detection rule
Tier 0 Device	Frequent logon by any Tier 0 identity
Tier 1 Device	Frequent logon by any Tier 1 identity
Tier 2 Device	Frequent logon by users from ORG-FINANCE / ORG-HR (or other custom sensitive groups)
Tier 3 Device	Default — no privileged logons in 3-day window

EG SIGNALS

isDomainController,
isExchangeServerDnsName,
isInternetFacing — flow
through as tier signals.

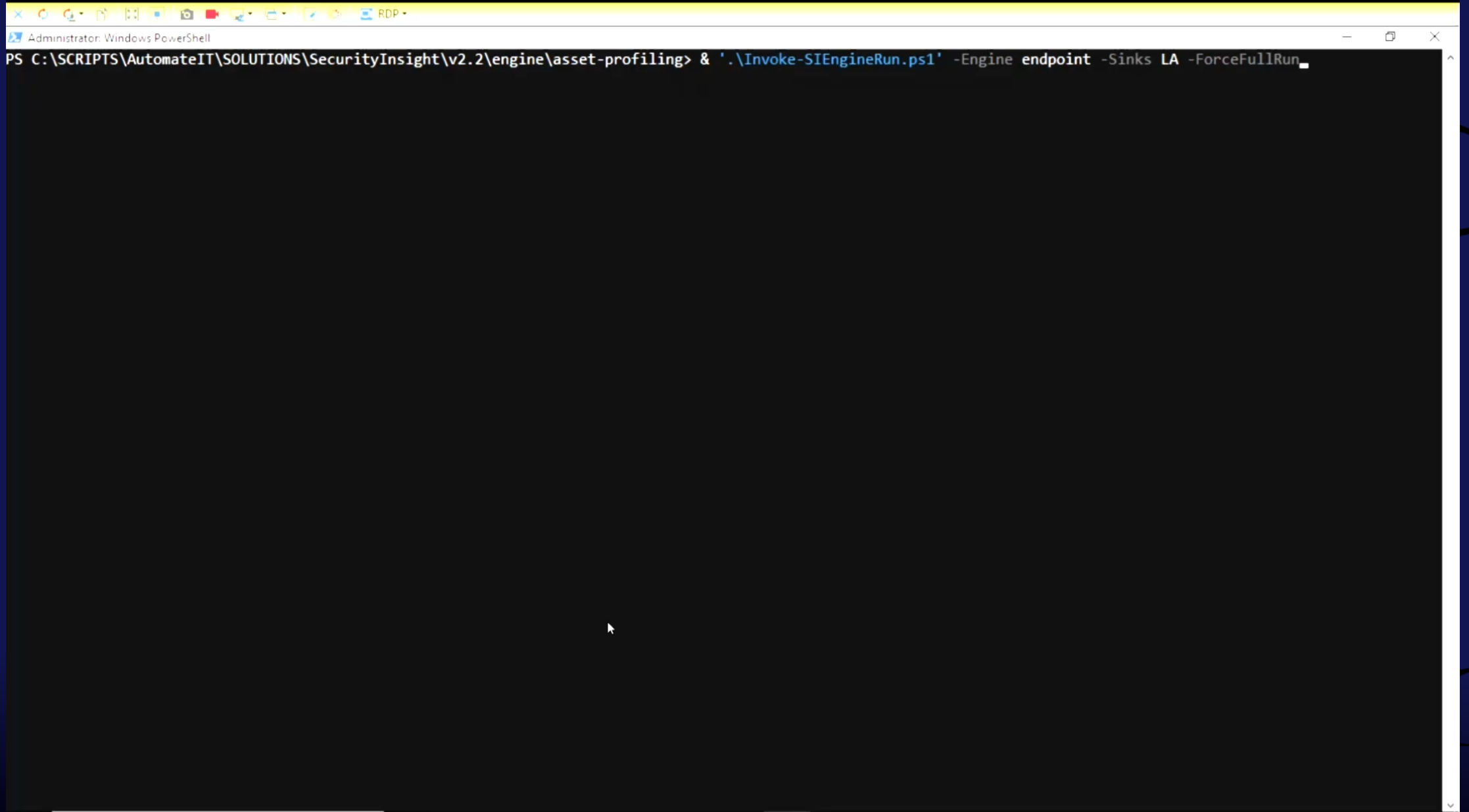
TVM SOFTWARE MATCHES

500-app server-app catalog:
Active Directory Certificate
Services, SCCM, Exchange,
etc.

MDE MACHINE TAGS

MachineTagPatterns from
regex match on existing MDE
tags.

DEMO: Asset Profiling – Endpoint – v2.2 (new)



A screenshot of a Windows PowerShell terminal window. The title bar reads "Administrator: Windows PowerShell". The command prompt shows the following command being entered:

```
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\engine\asset-profiling> & '.\Invoke-SIEngineRun.ps1' -Engine endpoint -Sinks LA -ForceFullRun
```

The terminal window is mostly black, indicating that the command has been executed but no output is visible yet. A mouse cursor is visible at the bottom center of the terminal area.

Advanced hunting

Selected workspace: log-platform-management-securityinsight

Help resources

Query resources report



New query* x New query* x New query* x New query* x New query* x New query* x +

Query Run query Create summary rule Create detection rule 30,000 (Default) Last 24 hours

```
1 SI_Endpoint_Profile_CL
2 | where CollectionTime == toscalar(SI_Endpoint_Profile_CL | summarize max(CollectionTime))
3 | where AssetName startswith "dc"
4 | project-away TimeGenerated
5 | project-reorder DisplayName, Tier, OsPlatform, RdpAllowConnections, RdpNlaRequired, cmdbName, cmdbCriticality
```

Results Query history Getting started

Export Show empty columns

2 items

Search

00:02:31 Low



Filters: Add filter

☐ DisplayName	☐ Tier	☐ OsPlatform	☐ RdpAllowConnecti...	☐ RdpNlaRequired	☐ cmdbName	☐ cmdbCriticality
☐ > dc3	0	WindowsServer2019	True	False	Active Directory	Critical
☐ > dc1	0	WindowsServer2022	True	False	Active Directory	Critical



DEMO: Asset Detection Rules – AD DC – v2.2 (new)

```
C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\asset-profiling-enrichment\endpoint\AssetProfileByApplicationServiceDetection\ADDomainController.locked.yaml - Notepad++ [Administrator]
File Edit Search View Encoding Language Settings Tools Macro Run Plugins Window ?
SecurityInsight_RiskAnalysis_Queries_Locked.yaml SecurityInsight_RiskAnalysis_Queries_Locked_legacy.yaml SecurityInsight_RiskAnalysis_Queries_Locked - Mix Not happy.yaml AssetProfileByDeviceType.locked.yaml VisualCron.c

34         - '(?i)domain.controller'
35         - '(?i)tier.?0'
36         - '(?i)^pdc$'
37         - '(?i)rodc'
38         - '(?i)read.only.dc'
39     - kind: egKustoQuery
40     query: |
41         ExposureGraphNodes
42         | where NodeLabel has "device"
43           or NodeLabel has "microsoft.compute/virtualmachines"
44           or NodeLabel has "microsoft.hybridcompute/machines"
45         | extend rawData = todynamic(NodeProperties).rawData
46         | where tobool(rawData.isExcluded) == false
47         | where tostring(rawData.deviceType) == "Server"
48         | where tolower(tostring(rawData.onboardingStatus)) == "onboarded"
49         | project NodeId, NodeName, NodeLabel, rawData, EntityIds
50         | extend
51           confidenceHigh = iff(isnull(rawData.criticalityConfidenceHigh), dynamic([]), todynamic(rawData.criticalityConfidenceHigh))
52           confidenceLow  = iff(isnull(rawData.criticalityConfidenceLow),  dynamic([]), todynamic(rawData.criticalityConfidenceLow))
53         | extend
54           DetectedRoles = strcat_array(array_concat(confidenceHigh, confidenceLow), ";")
55         | where DetectedRoles has "DomainController"
56     set:
57         Tier: 0
58         Purpose: 'Domain Controller'
59         Category: 'Server Roles'
60         cmdbId: 1
61         cmdbDataSensitivity: 'Restricted'
62
```

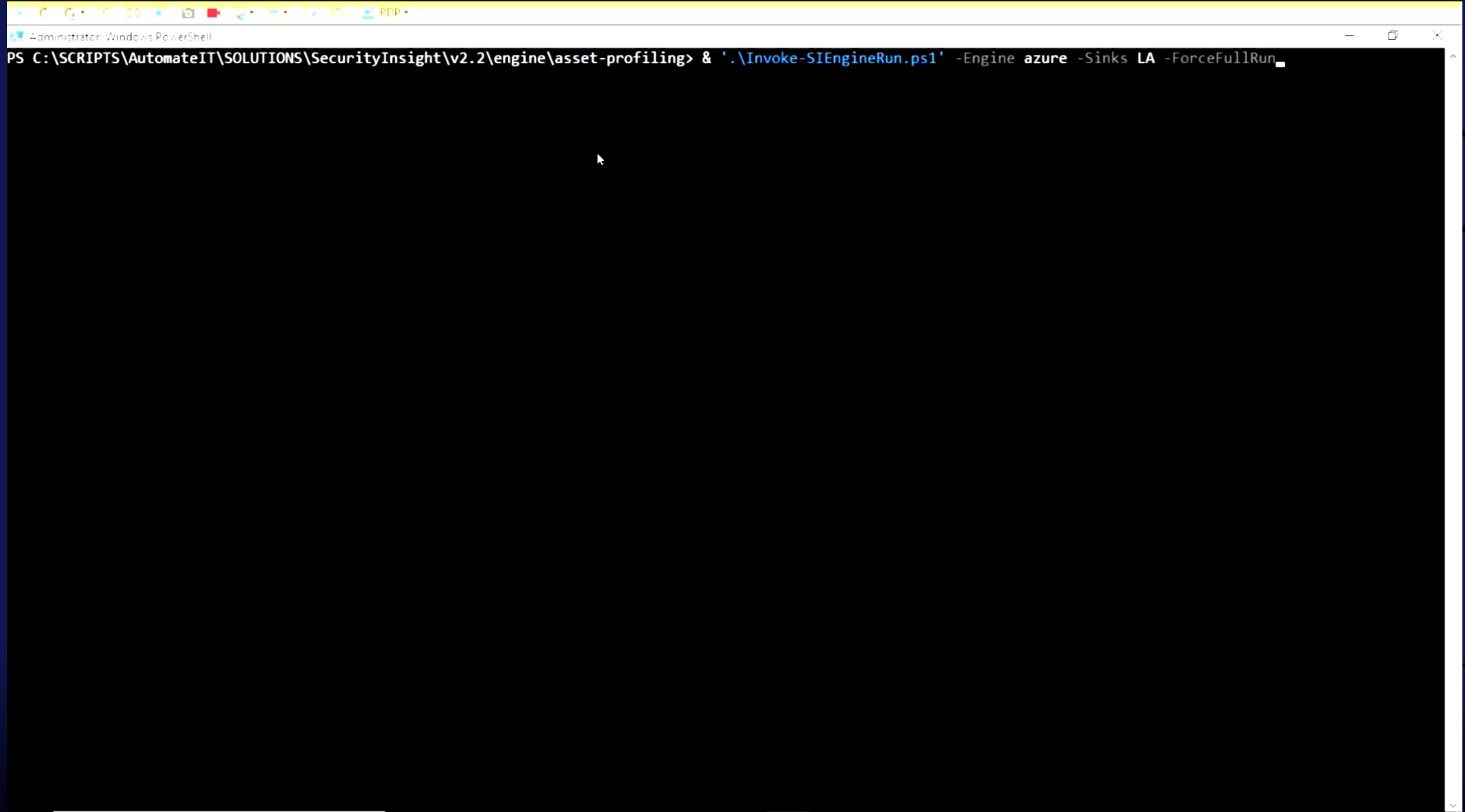
YAML Ain't Markup Language

length : 2,461 lines : 63 Ln : 55 Col : 51 Pos : 2,302 Unix (LF) UTF-8 INS

Azure Classification

Signal	Weight	What it measures
Subscription name pattern	0.8	Prod / Prd → T0–T1; Dev / PoC / Test / Sandbox → T2–T3 (customer-extensible regex list)
Azure resource hierarchy	0.7	Level 1 (root MG) = T0; level 2 (MG/Sub with Owner / Contributor / User Access Admin) = T0; level 3 = T1; level 4+ = T2
Tags	0.6	env, Environment, Environment-Type map to tier — customer-extensible mapping table
CAF landing-zone naming	0.6	Microsoft CAF naming auto-mapped: platform-* / corp-* = T1, online-* = T2
Services — identity / take-over	contrib.	Resource exposes a managed identity holding high-priv RBAC → MI compromise = parent compromise; weights the parent accordingly

DEMO: Asset Profiling – Azure – v2.2 (new)



The image shows a screenshot of a Windows PowerShell terminal window. The title bar at the top reads "Administrator: Windows PowerShell". The command prompt shows the current directory as "C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\engine\asset-profiling". The command being entered is: `& '.\Invoke-SIEngineRun.ps1' -Engine azure -Sinks LA -ForceFullRun`. The terminal background is black, and the text is white. A mouse cursor is visible in the center of the terminal window.

```
Administrator: Windows PowerShell
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\engine\asset-profiling> & '.\Invoke-SIEngineRun.ps1' -Engine azure -Sinks LA -ForceFullRun
```


Advanced hunting

</> New query* x

</> New query* x

</> New query* x

</> New query* x

</> New query* x

+

>

^ Query

Run query

📄

📄

Create summary rule

Create detection rule

30,000 (Default)

Last 24 hours

```
1 SI_Azure_Profile_CL
2 | where CollectionTime == toscalar(SI_Azure_Profile_CL | summarize max(CollectionTime))
3 | where IsPubliclyExposed == "true"
4 | project-away TimeGenerated
5 | project AssetName, ServiceType, Tier, ParentMG_Structure
6
```

Results

Query history

Getting started

Export

Show empty columns

45 items

Search

00:00.830

Low

🌐

🔗

🌐

🔗

Filters:

Add filter

AssetName	ServiceType	Tier	ParentMG_Structure
> stdemosecurityinsight	storageaccounts	3	Tenant Root Group/2LINKIT/Platform/Platform-Management/sg-platform-sponsorship-m
> rgeldkautomationa1c7	storageaccounts	3	Tenant Root Group/2LINKIT/Platform/Platform-Management/sg-platform-sponsorship-m
> oai-mortenknuksen-security-insight	accounts	3	Tenant Root Group/2LINKIT/Landingzones/LZ_Online/MVP Test & Demo Environments/Mi
> stservicemonitor	storageaccounts	3	Tenant Root Group/2LINKIT/Landingzones/LZ_Online/MVP Test & Demo Environments/sg
> defendersecurityadvisor-resource	accounts	3	Tenant Root Group/2LINKIT/Landingzones/LZ_Online/MVP Test & Demo Environments/Mi
> pim-role-advisor	accounts	3	Tenant Root Group/2LINKIT/Landingzones/LZ_Online/MVP Test & Demo Environments/Mi
> pip-eldk-automation-webhook	publicipaddresses	3	Tenant Root Group/2LINKIT/Platform/Platform-Management/sg-platform-sponsorship-m
> eps-demo-dc1_osdisk_1_eef8b2737873	disks	3	Tenant Root Group/2LINKIT/Landingzones/LZ_Online/MVP Test & Demo Environments/sg
> stsharingmortenknuksen	storageaccounts	3	Tenant Root Group/2LINKIT/Platform/Platform-Management/sg-platform-sponsorship-m

Identity Classification

Tier from actual permissions — six sources combined, highest privileged tier wins

Source	What's read
Entra directory roles (permanent)	Global Admin, Privileged Role Admin, etc. → T0 / T1
Entra directory roles (PIM eligible)	Roles user can elevate into — counted as future risk
Group inheritance	Transitive group membership + PIM-for-Groups expansion (recursive)
Entra app permissions	API permissions: Application + Delegated grants
Azure RBAC (scope-aware)	Owner @ root MG = T0; Reader @ RG = T3; etc.
AD groups (synced)	Built-in privileged groups + customer-defined ORG-* groups

Scale of the Complexity!

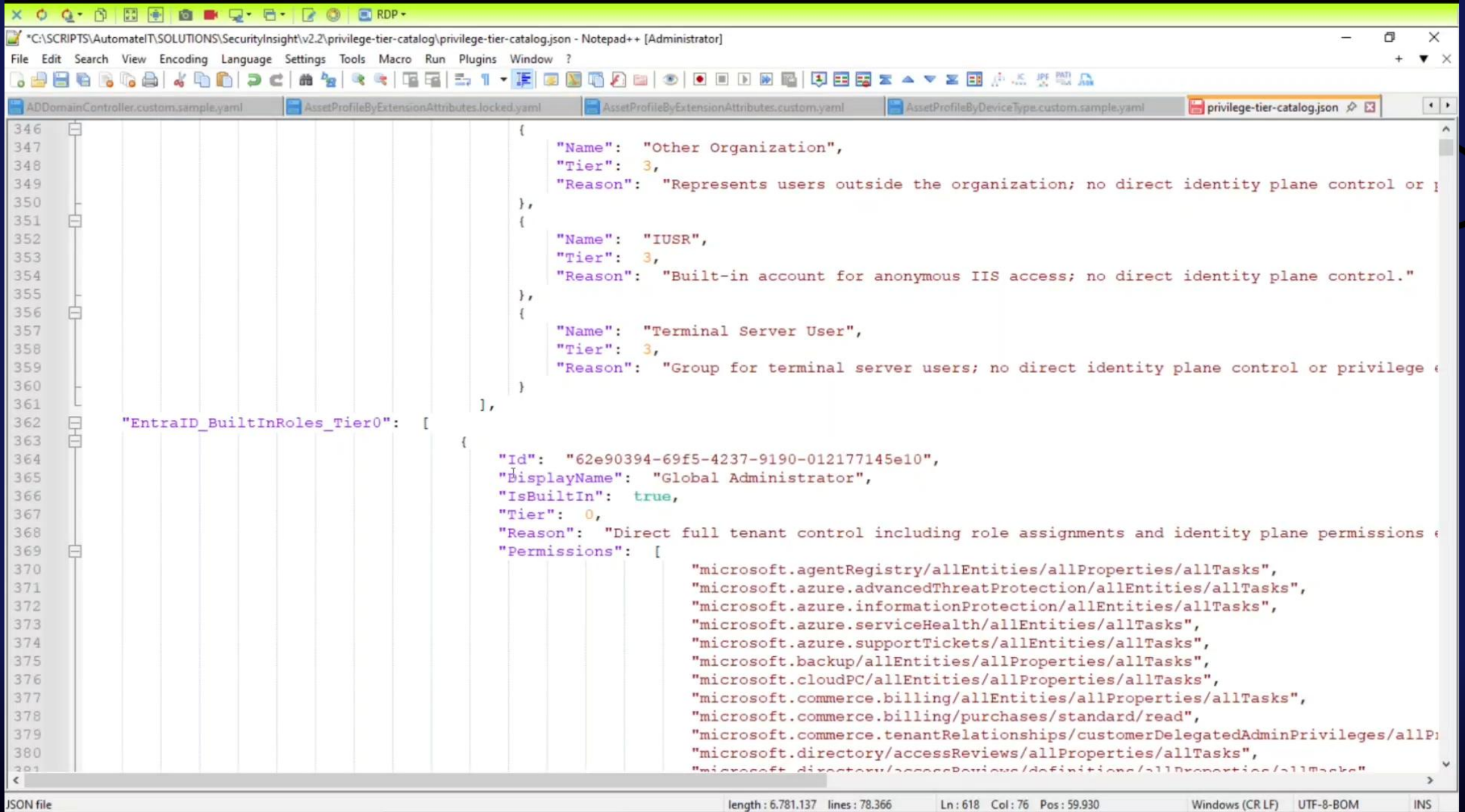
Permissions & Roles – May 3rd, 2026

Category	Tier 0	Tier 1	Tier 2	Tier 3	Total
AD built-in groups	9	6	3	51	69
Entra built-in roles	5	23	20	95	143
Entra / Graph API permissions	2	59	138	1,027	1,226
Azure built-in roles	3	14	130	726	873
All categories — grand total	19	102	291	1,899	2,311

Complexity over time

Date	24 th April 2026	30 th Jan 2026	9 th June 2025	27 th May 2024
Entra ID Roles	143	134	123	110
Azure Roles	873	838	688	542

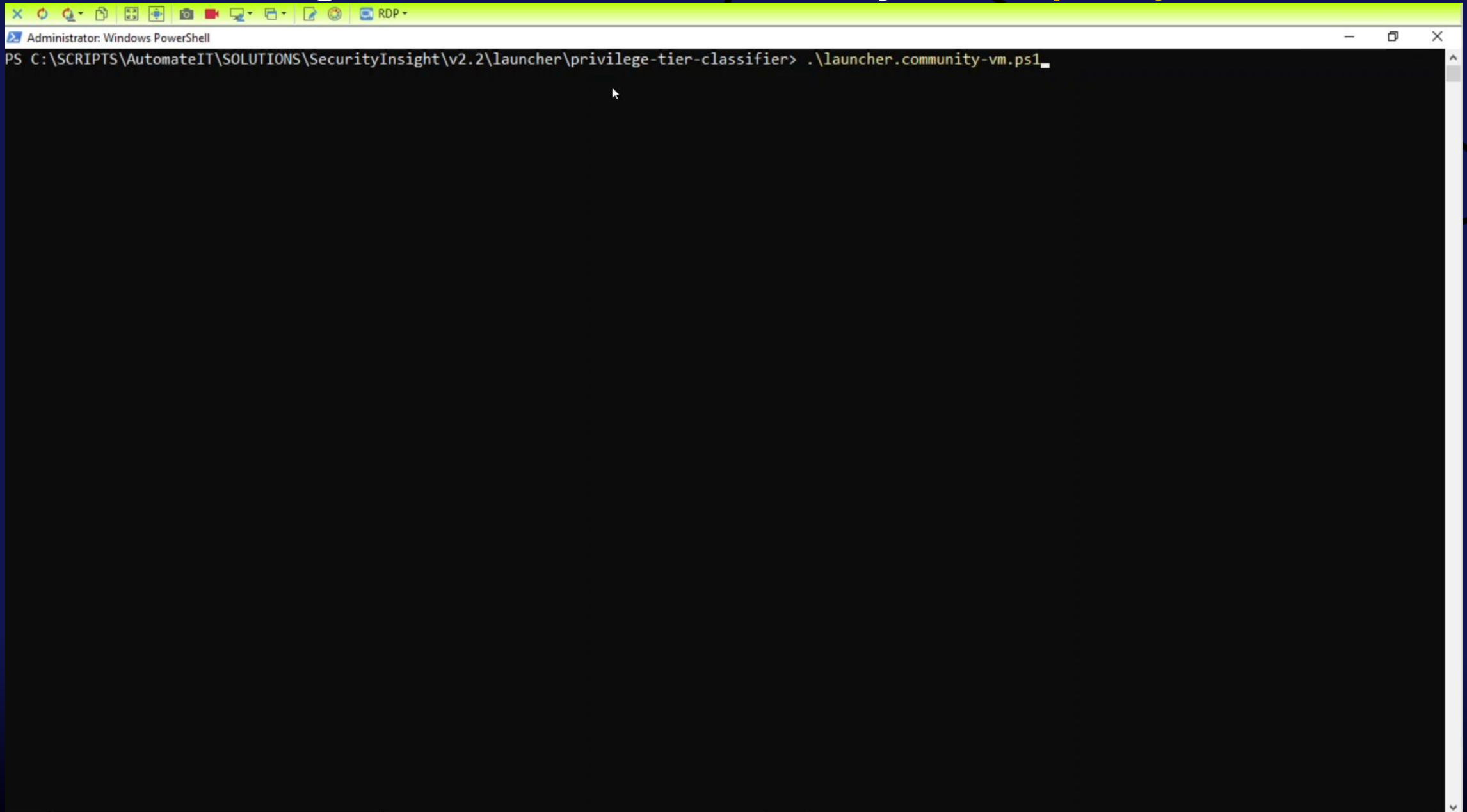
DEMO: Privilege Tier Catalog – Identity – v2.2 (new)



```
346 {
347   "Name": "Other Organization",
348   "Tier": 3,
349   "Reason": "Represents users outside the organization; no direct identity plane control or p
350 },
351 {
352   "Name": "IUSR",
353   "Tier": 3,
354   "Reason": "Built-in account for anonymous IIS access; no direct identity plane control."
355 },
356 {
357   "Name": "Terminal Server User",
358   "Tier": 3,
359   "Reason": "Group for terminal server users; no direct identity plane control or privilege e
360 }
361 ],
362 "EntraID_BuiltInRoles_Tier0": [
363 {
364   "Id": "62e90394-69f5-4237-9190-012177145e10",
365   "DisplayName": "Global Administrator",
366   "IsBuiltIn": true,
367   "Tier": 0,
368   "Reason": "Direct full tenant control including role assignments and identity plane permissions e
369   "Permissions": [
370     "microsoft.agentRegistry/allEntities/allProperties/allTasks",
371     "microsoft.azure.advancedThreatProtection/allEntities/allTasks",
372     "microsoft.azure.informationProtection/allEntities/allTasks",
373     "microsoft.azure.serviceHealth/allEntities/allTasks",
374     "microsoft.azure.supportTickets/allEntities/allTasks",
375     "microsoft.backup/allEntities/allProperties/allTasks",
376     "microsoft.cloudPC/allEntities/allProperties/allTasks",
377     "microsoft.commerce.billing/allEntities/allProperties/allTasks",
378     "microsoft.commerce.billing/purchases/standard/read",
379     "microsoft.commerce.tenantRelationships/customerDelegatedAdminPrivileges/allP
380     "microsoft.directory/accessReviews/allProperties/allTasks",
381     "microsoft.directory/accessReviews/definitions/allProperties/allTasks"
```

JSON file length: 6.781.137 lines: 78.366 Ln: 618 Col: 76 Pos: 59.930 Windows (CR LF) UTF-8-BOM INS

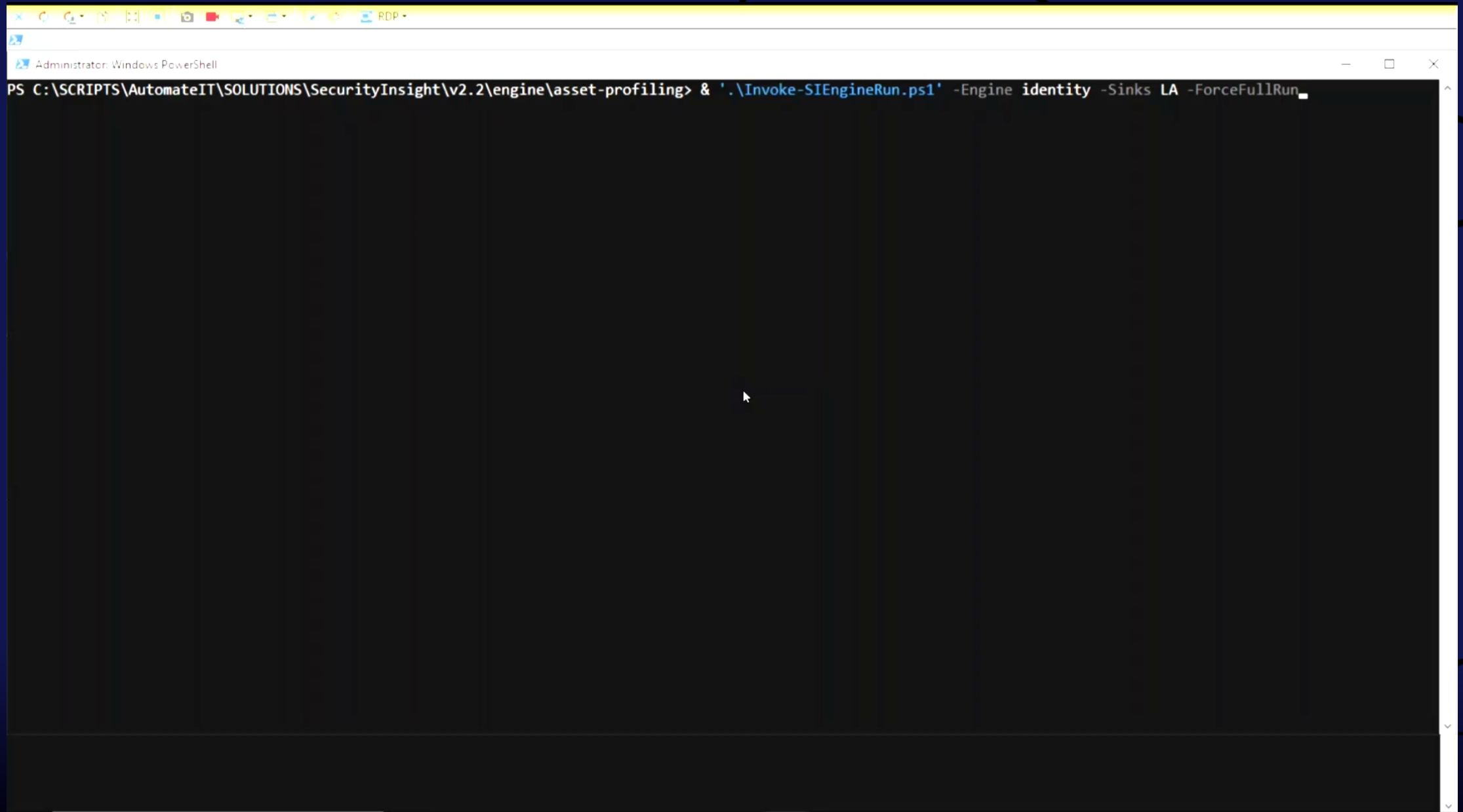
DEMO: Privilege Tier Classifier – Identity – v2.2 (new)



The image shows a screenshot of a Windows PowerShell terminal window. The window has a title bar that reads "Administrator: Windows PowerShell". The command prompt shows the current directory as "C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\privilege-tier-classifier" and the command being executed is ".\launcher.community-vm.ps1". The terminal output is currently blank, and the cursor is positioned at the end of the command line.

```
Administrator: Windows PowerShell
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\privilege-tier-classifier> .\launcher.community-vm.ps1
```

DEMO: Asset Profiling – Identity – v2.2 (new)



The image shows a screenshot of a Windows PowerShell terminal window. The window title is "Administrator: Windows PowerShell". The command prompt shows the following command being entered:

```
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\engine\asset-profiling> & '.\Invoke-SIEngineRun.ps1' -Engine identity -Sinks LA -ForceFullRun
```

The command is partially entered, with the cursor at the end of the line. The terminal background is black, and the text is white. The window has a standard Windows taskbar at the top with various icons.

Advanced hunting

Selected workspace: log-platform-management-securityinsight

Help resources

Query resources rep

New query* x New query* x New query* x New query* x New query* x New query* x +

Query Run query

Create summary rule Create detection rule 30,000 (Default) Last 2

```
1 SI_Identity_Profile_CL
2 | where CollectionTime == toscalar(SI_Identity_Profile_CL | summarize max(CollectionTime))
3 | where ObjectType startswith "User"
4 | project-away TimeGenerated
5 | project-reorder AssetName, Tier, AzureRolesVerdict_TopMatch, EntraRolesPermanentVerdict_TopMatch
```

Results Query history Getting started

Export

Show empty columns

72 items

Search

00:01.697 Low

AssetName	Tier	AzureRolesVerdict_TopMatch	EntraRolesPermanentVerdict_TopM...
> riskyuser	3		
> Peter Bjerre Knudsen	3		
> Morten Knudsen (Admin, Cloud, ID)	0	Owner @ Subscription: ad2ea027-413e-4edc-bc92-cf8b9b5c9a6	Authentication Administrator
> Henrik Wojcik (2LINKIT)	3		
> Invoices	3		
> Glenna Segall	3		
> Sponsor	0	Owner @ Management Group: f0fa27a0-8e7c-4f63-9a77-ec9478	
> PAW Demo (Admin, Cloud, ID, L0, T0, 0			

Advanced hunting

Selected workspace: log-platform-management-securityinsight

Help resources

Query resources report

New query* x New query* x New query* x New query* x New query* x +

Query Run query Create summary rule Create detection rule 30,000 (Default) Last 24 hours

```
1 SI_Identity_Profile_CL
2 | where CollectionTime == toscalar(SI_Identity_Profile_CL | summarize max(CollectionTime))
3 | where MfaIsRegistered == false
4 | where ObjectType == "User"
5 | where AccountEnabled == true
6 | project-away TimeGenerated
```

Results Query history Getting started

Export Show empty columns 16 items Search 00:02.26 Low

DisplayName	Tier	AccountEnabled	AdBuiltinGroupsVe...	AdBuiltinGroupsVe...	AdminCount	AzureRolesVerdi
> On-Premises Directory Synch...	1	true	0	0		0
> Blake Cherry	3	true	0	0		0
> PIM Dummy Admin (Admin, D,	3	true	0	0		0
> Anders Kongsted (2LINKIT)	3	true	0	0		0
> Printer	3	true	0	0		0
> Morten Knudsen (Managed Cpe	3	true	0	0		0
> Simon Skotheimsvik	3	true	0	0		0
> shareddevicewhfb	3	true	0	0	0	0

Advanced hunting

Selected workspace: log-platform-management-securityinsight

Help resources

Query resources report

New query* x New query* x New query* x New query* x New query* x +

Query Run query Create summary rule Create detection rule 30,000 (Default) Last 24 hours

```
1 SI_Identity_Profile_CL
2 | where CollectionTime == toscalar(SI_Identity_Profile_CL | summarize max(CollectionTime))
3 | where Tier == 0
4 | where ObjectType startswith "ServicePrincipal"
5 | project-away TimeGenerated
6 | project-reorder AssetName, Tier, EntraApiPermsApplicationVerdict TopMatch, EntraAppPermissions Application
```

Results Query history Getting started

Export Show empty columns 13 items Search 00:01.389 Low

Filters: Add filter

AssetName	Tier	EntraApiPermsApplicationVerdict_TopMatch	EntraAppPermissions_Application
> moktest14 - Automation - Az	0	RoleManagementPolicy.ReadWrite.Directory	["Policy.ReadWrite.IdentityProtection","RoleManagement.ReadV
> 2LINKIT - Onboarding and	1 0	AppRoleAssignment.ReadWrite.All	["Application.ReadWrite.All","Directory.ReadWrite.All","AppRole.
> moktest15 - Automation - Az	0	RoleManagementPolicy.ReadWrite.Directory	["Policy.ReadWrite.IdentityProtection","RoleManagement.ReadV
> Automation Sign-in, Keyva	0	User.ReadWrite.All	["Directory.Read.All","User.ReadWrite.All","TermStore.ReadWrite
> SOLAR, Automation, High P	0	Exchange.ManageAsApp	["Exchange.ManageAsApp","IdentityUserFlow.ReadWrite.All","A
> moktest13 - Automation - Az	0	RoleManagementPolicy.ReadWrite.Directory	["Policy.ReadWrite.IdentityProtection","RoleManagement.ReadV
> 2LINKIT - Automation - Az	0	RoleManagementPolicy.ReadWrite.Directory	["Policy.ReadWrite.IdentityProtection","SecurityAlert.ReadWrite..
> 2LINKIT - Automation - O3	0	RoleManagementPolicy.ReadWrite.Directory	["Tasks.Read","User.Read.All","full_access_as_app","Organization
> moktest16 - Automation - A		RoleManagementPolicy.ReadWrite.Directory	["Policy.ReadWrite.IdentityProtection","RoleManagement.ReadV

Advanced hunting

Selected workspace: log-platform-management-securityinsight

Help resources

Query resources report

New query* x New query* x New query* x New query* x New query* x New query* x +

Query Run query

Create summary rule Create detection rule 30,000 (Default) Last 24 hours

```
1 SI_Identity_Profile_CL
2 | where CollectionTime == toscalar(SI_Identity_Profile_CL | summarize max(CollectionTime))
3 | extend Upn = tostring(Upn), DisplayName = tostring(DisplayName), Tier = tostring(Tier)
4 | where Upn =~ "anne@walmart.dk"
5 | mv-expand Rule = SIRules
6 | extend
7 | ... RuleId = tostring(Rule.RuleId),
8 | ... DetectionId = tostring(Rule.DetectionId),
9 | ... RuleTier = toint(Rule.Tier),
10 | ... Purpose = tostring(Rule.Purpose),
11 | ... Category = tostring(Rule.Category)
12 | distinct DisplayName, Tier, RuleId, DetectionId, RuleTier, Purpose, Category
```

Results Query history Getting started

Export Show empty columns 1 item Search 00:01.567 Low

Filters: Add filter

DisplayName	Tier	RuleId	DetectionId	RuleTier	Purpose	Category
> Anne Walторp	2	AssetProfileByGroupMemk	OrgFinanceMember	2	Finance team member	Group Membership

External Risk Analysis – Shodan (shodan.io)

INPUT

Dynamic

- Public-IP information detected from endpoints

Static

- Custom IP addresses (customer-supplied target list)

ENRICHMENT

Shodan (shodan.io)

- Bulk per-IP /host lookups, cached 7 days
- On-demand /scan opt-in & credit-budgeted

CMDB mapping

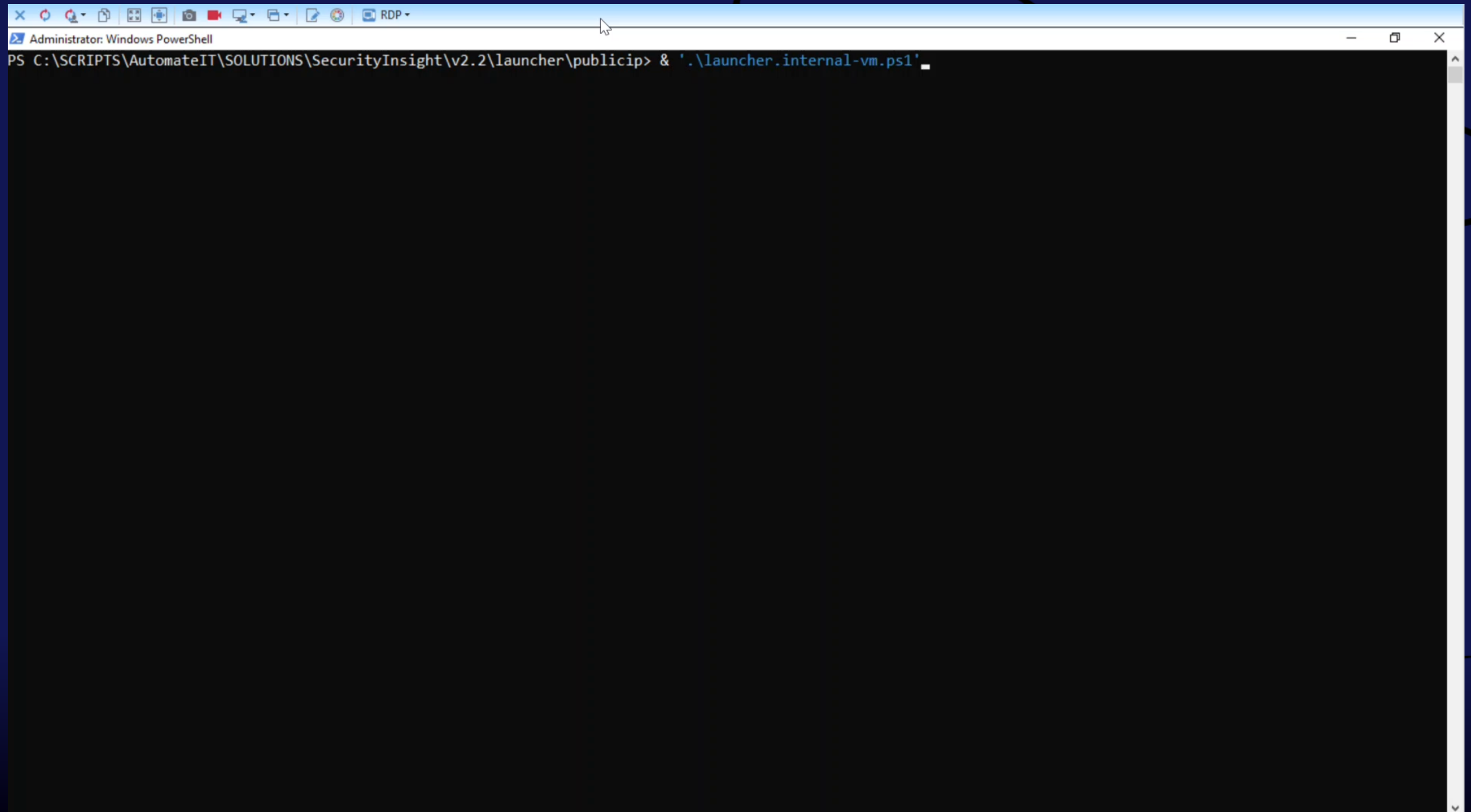
- IP / hostname → owner, environment, criticality
- Joins external findings to internal asset context

OUTPUT

Risk fields

- open ports
- service banners
- CVE list & max CVSS
- ASN, ISP, country
- last-seen-by-Shodan

DEMO: Asset Profiling – Public IP – v2.2 (new)



The image shows a screenshot of a Windows PowerShell window running as an administrator. The window title is "Administrator: Windows PowerShell". The command prompt shows the current directory as "C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\publicip" and the command being executed is "& '.\launcher.internal-vm.ps1'". The command prompt is currently empty, indicating the command has been entered but not yet executed.

```
Administrator: Windows PowerShell
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\publicip> & '.\launcher.internal-vm.ps1'
```

```
1 SI_VulnerabilityPIP_CL
2 | where TimeGenerated > ago(8d)
3 | summarize arg_max(CollectionTime, *) by IPAddress
4
```

Results Chart

IpAddress	CollectionTime	TimeGenerated [Local Time]
172.205.146.248	2026-05-04T15:37:11.0000000Z	5/4/2026, 10:37:12.8
IpAddress	172.205.146.248	
CollectionTime	2026-05-04T15:37:11.0000000Z	
TimeGenerated [UTC]	2026-05-04T15:37:12.8488811Z	
AssetEngine	endpoint	
AssetName	MGMT1	
AssetTier	0	
cmdbCriticality	Medium	
cmdbName	Automation	
HasShodanRecord	false	
OpenPortCount	0	
ScanTime	2026-05-04T15:36:47.0000000Z	
VulnCount	0	

```
1 SI_VulnerabilityPIP_CL
2 | .where TimeGenerated > ago(8d)
3 | .summarize arg_max(CollectionTime, *) by IPAddress
4 | .where OpenPorts > 0 or VulnCount > 0
5
```

Results

Chart

IpAddress	CollectionTime	TimeGenerated [Local ...]	AssetEngine	AssetName
[22,80,123,9929,31337]				
OpenPorts				
0	22			
1	80			
2	123			
3	9929			
4	31337			
Org Linode				
ScanTime 2026-05-04T15:36:54.0000000Z				
VulnCount 100				
Vulns ["CVE-2006-20001","CVE-2007-4...				
0	CVE-2006-20001			
1	CVE-2007-4723			

4

Risk Analysis

Threat Assessment



SecurityInsight Risk Analysis

```
graph TD; S1[1. Schedule] --> S2[2. Discover]; S2 --> S3[3. Collect]; S3 --> S4[4. Analyze]; S4 --> S5[5. Classify]; S5 --> S6[6. Output / Distribute];
```

1. Schedule

Decide if it's time to run.

- **Tier-aligned cadence** — follows the same T0-to-T3 rhythm as profiling.
- **Pre-flight check** — verifies SPN, OpenAI and Log Analytics before starting.

2. Discover

Load the risk catalog.

- **Reports** — loaded from versioned YAML — locked + custom.
- **One report = one question** — e.g. “which devices missing EDR sensor?”

3. Collect

Run every risk question.

- **KQL execution** — against Defender XDR and LogAnalytics data.
- **Built for scale** — results paged + bucketed for >30k-row reports. Multiple instances (scale-up/down)

4. Analyze

Score every result row.

- **Risk factors** — from finding severity + exposure modifiers.
- **Risk = consequence × probability** — asset tier drives consequence.

5. Classify

Generate exec-ready insight.

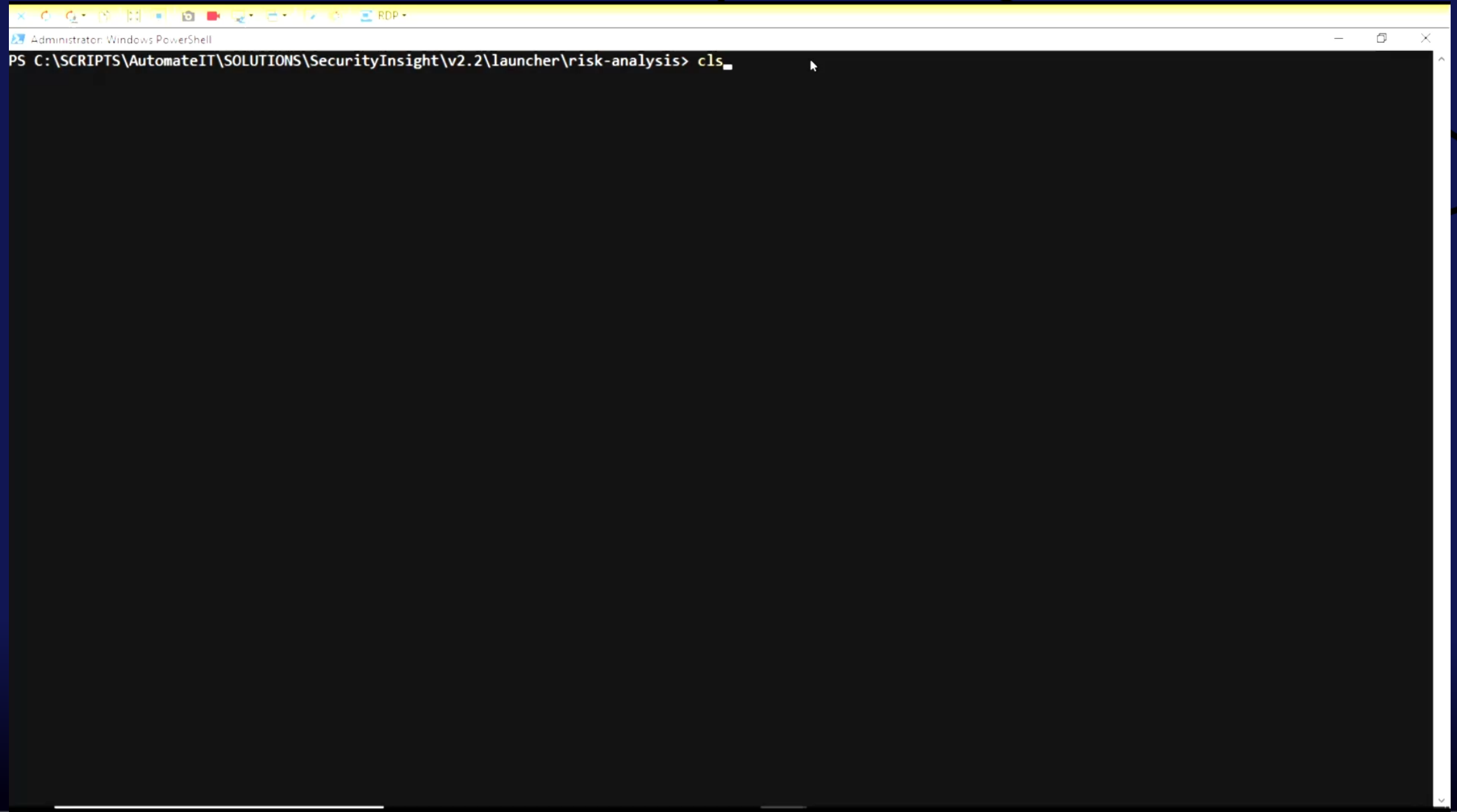
- **Executive summary** — AI narrates the top-N highest-risk rows per report.
- **Opt-in + cost-bounded** — controlled by the same AI spend ceiling.

6. Output / Distribute

Put findings in the right hands.

- **LA + workbook + Power BI** — summary + detailed buckets, dashboards refresh.
- **Distribution options** — email summaries, Azure Blob upload.

DEMO: Risk Analysis – v2.2 (new)



A screenshot of a Windows PowerShell terminal window. The title bar at the top reads "Administrator: Windows PowerShell". The command prompt shows the current directory as "C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\risk-analysis" and the command "cls" has been entered, which clears the screen. The rest of the terminal area is black.

```
Administrator: Windows PowerShell
PS C:\SCRIPTS\AutomateIT\SOLUTIONS\SecurityInsight\v2.2\launcher\risk-analysis> cls
```

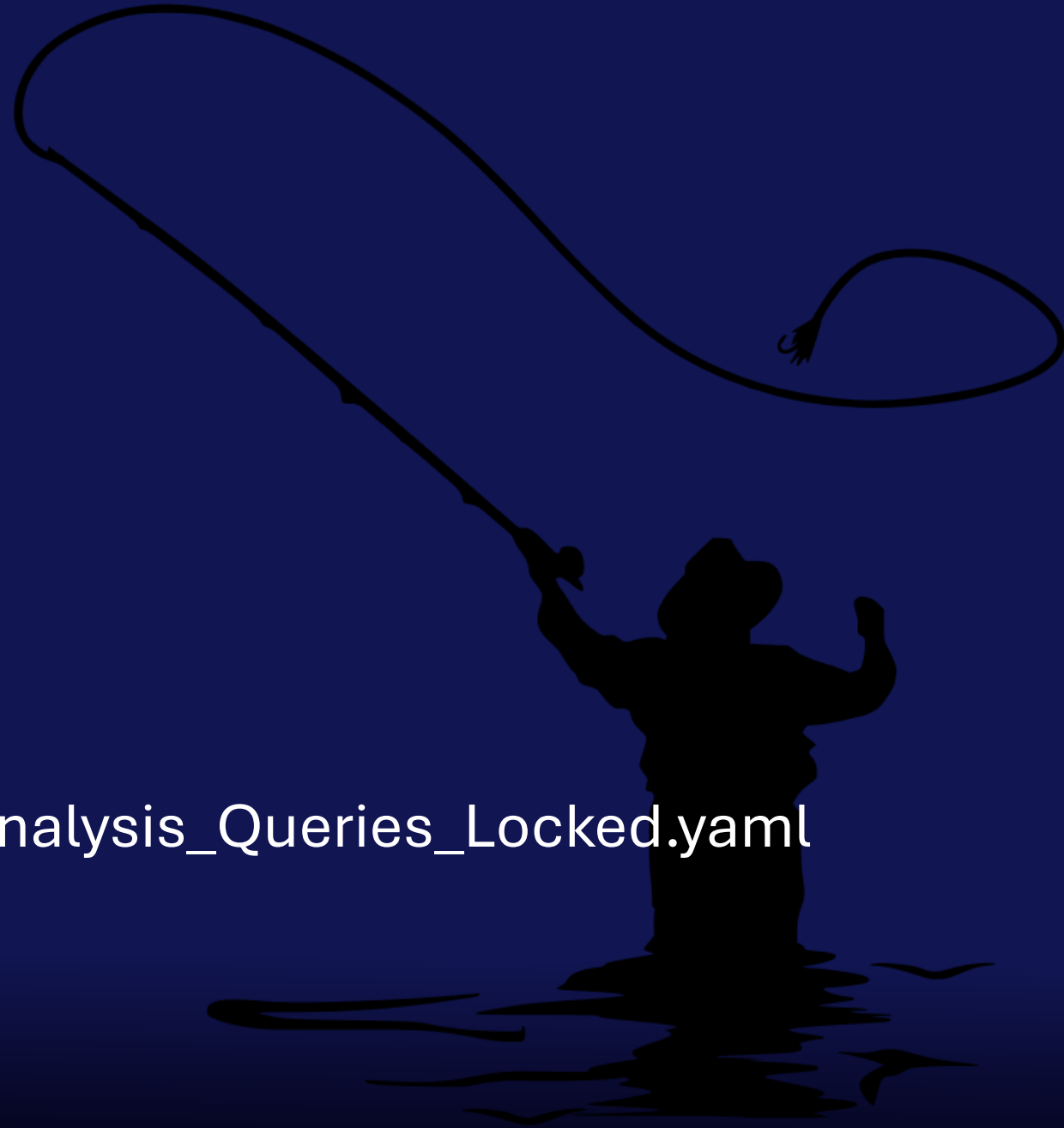
Risk Analysis Queries/Reports

136 total, +22000 lines of Kusto 😊

Area	Count	What's covered
Identity	110	MFA gaps, stale/privileged accounts, SPN hygiene, PIM, Break Glass, sign-in anomalies, shadow admins, role/permission abuse, privileged-user logon paths, Conditional Access bypass, SPN owner mismatch (55 reports × Summary + Detailed)
Endpoints / Devices	6	Missing CVEs (Summary + Detailed), device recommendations (Summary + Detailed)
Azure	2	Azure recommendations (Summary + Detailed)
Attack Paths	12	GitHub → Azure, Public IP → VM CVE exploitation, Identity → Privileged Resources, Data Sensitivity → Exposed Credentials, Vulnerable device → Azure lateral movement, Credential-based lateral movement (6 paths × Summary + Detailed)
PublicIP / Shodan	4	Open ports (Summary + Detailed), Vulnerabilities/CVEs (Summary + Detailed)
Engine self-meta	2	RiskAnalysis_Summary + _Detailed (engine reports about its own runs)

DEMO

Let's see query files (YAML) - RiskAnalysis_Queries_Locked.yaml



SecurityInsight v2 Integration Options

Output options

- ◆ **Send Excel spreadsheet per mail**
- ◆ **Send Risk Analytics data to LogAnalytics** workspace, to be used with Kusto Queries (alerting) & Azure Workbooks
- ◆ Automatic upload of **JSON file** to **UNC path**, based on Risk Analysis Summary
- ◆ Automatic upload of **JSON file** to **Azure Storage Account (Blob)**, based on Risk Analysis Summary
- ◆ **Power BI workspace** (currently being developed)
- ◆ **Azure Workbooks** (currently being developed)

Use Cases

- ◆ **Daily Security Prioritization Meetings** - top risks
- ◆ **Baseline new security & introduce Just-In-Time Delegations**
- ◆ **Disable/Clean-up legacy identity assets** (old SPNs/MIs)
- ◆ **Detect Shadow IT delegations**
- ◆ **ServiceNow integration** open/close tickets based on active/close incidents using Kusto lookup and use unique TraceID (hashvalue of TraceName)
- ◆ **Alerting using Kusto** (send escalation text/mail if certain things happen or numbers change drastically)
- ◆ **Management reporting using Power BI** (management love graphics, closed tickets, timelines, etc.)
- ◆ **Compliance Reporting** (compare snapshot of permissions between 2 collection points using Kusto against IdentityAssets table - what changed in permissions?)



CMDB integration — ServiceNow

Optional enrichment: pull authoritative asset metadata from ServiceNow and map back to enriched assets.



OPTIONAL — REVERSE MAPPING

SecurityInsight → CMDB asset mapping

Match keys produced by the asset-profiling & enrichment phases (DNS name, MDE machine ID, Azure resource ID, public IP) are written back to suggest CMDB linkage for unmapped assets — disabled by default, opt-in per workspace.

SecurityInsight Agents *(investigating)*

- ◆ **Asset Owner Resolver** — turns "this DC is at risk" into "email Sarah."
- ◆ **Remediation Playbook Linker** — adds a "How to fix" link to every finding.
- ◆ **Blast-Radius Narrator** — one sentence on what's reachable if this asset falls.
- ◆ **Exploit Intel Enricher** — live CVE context (KEV, EPSS, PoC) adjusts probability.
- ◆ **Ticket Bridge Agent** — top findings land in ServiceNow / Jira / ADO, deduped.
- ◆ **Change-Window Scheduler** — maps fixes to maintenance windows per team.
- ◆ **Fix-Script Drafter** — generates safe -WhatIf remediation snippets.
- ◆ **Approval Routing Agent** — sends tier-0 fixes to the right approver automatically.
- ◆ **Rollback Plan Generator** — every fix ships with its undo script.
- ◆ **Remediation Progress Tracker** — closed, reopened, new, and MTTR per tier.
- ◆ **Burn-Down Dashboard Agent** — live risk-score trend after every run.
- ◆ **SLA Breach Detector** — escalates findings past their tier deadline.
- ◆ **False-Positive Feedback Loop** — turns "not a real issue" into a rule.
- ◆ **Attestation Agent** — tracks accepted-risk approvals and re-prompts on expiry.
- ◆ **Per-Team Digest Agent** — splits the Excel into team-scoped emails.
- ◆ **Executive Briefing Agent** — monthly CISO one-slide, AI-generated.
- ◆ **NIS2 / CIS Mapper** — tags findings to controls for auditor conversations.
- ◆ **Incident-to-Finding Correlator** — links live alerts to open risk items.
- ◆ **Community Query Harvester** — safety-checks shared YAMLS from Discussions.

5

Tier Definitions

We need to define a common framework of criticality – based on security
Can an attack gain access and do a tenant/domain takeover !



How we categorize a Security Recommendation into Severity?

Consequence Classifications

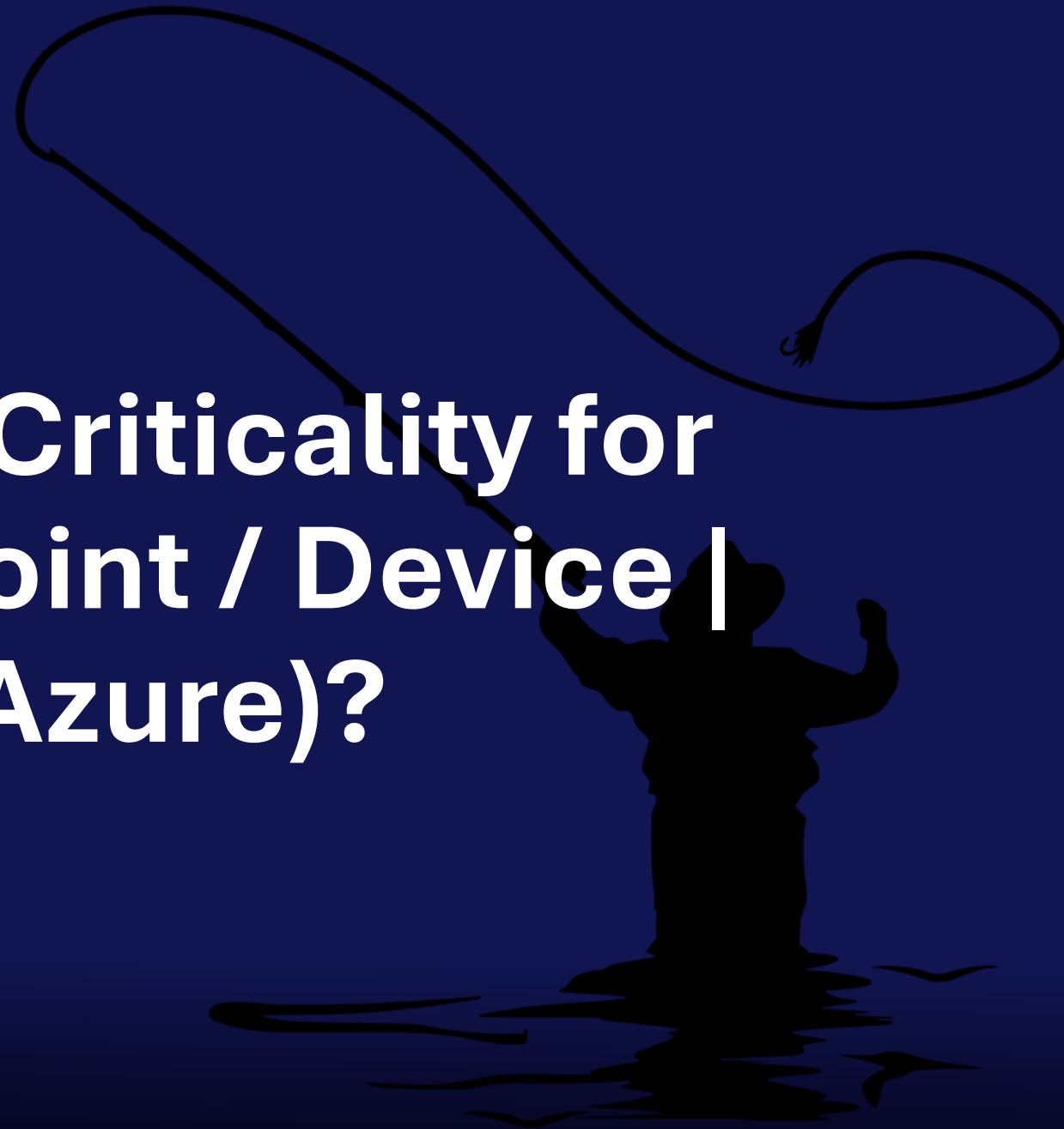


Severity Prioritization | Risk Score Definitions

Defender Score	Risk Impact	Attack Impact
10	Very High	Absence of this control gives attackers an immediate and decisive advantage. Either a critical attack path is left fully exposed, or a single exploitation leads directly to full environment compromise with no further steps required.
9	High	This control addresses weaknesses that are actively weaponized in the wild by ransomware operators, credential theft campaigns, and advanced persistent threat actors. Exploitation is well-documented, tooling is widely available, and remediation should be treated as urgent.
8	Medium-High	This control is a foundational hardening measure that meaningfully shrinks the attack surface and disrupts common lateral movement techniques While not immediately catastrophic if missing, its absence creates conditions that attackers routinely chain together to escalate privileges or move laterally.
5-7	Medium	This control reflects established security best practice and reduces exposure to known attack patterns. Exploitation is possible but less consistent, typically requiring specific environmental conditions or attacker patience. Prioritize after higher-severity items are addressed.
1-4	Low	This control contributes to security hygiene and long-term posture improvement. Missing controls in this range are unlikely to be directly targeted but may marginally increase the cost or noise for an attacker operating in the environment.

How we classify Criticality for Assets like Endpoint / Device | Identity | Cloud (Azure)?

Probability (Likelihood) Classifications



Criticality Prioritization | Risk Score Definitions

Criticality Level	Attack Impact	Defender Terms
Critical (Tier-0)	Immediate full environment compromise if taken Compromise of a Domain Controller, krbtgt account, or Global Administrator yields unrestricted control over every identity, credential, and resource in the environment. An attacker can forge Kerberos tickets, replicate the entire AD database, assign any Entra role, and persist indefinitely without detection. Recovery requires full forest rebuild.	Portal: Very High - tier 0 API: 0
High (Tier-1)	High impact, one or two pivots to full compromise Compromise of an Exchange server, Authentication Administrator, or jump server provides credential material, token abuse opportunities, or lateral movement paths that lead to tier 0 within one or two steps. An attacker can reset MFA, intercept authentication flows, abuse unconstrained delegation, or exploit ADCS misconfigurations to escalate without direct access to tier 0 assets.	Portal: High - tier 1 API: 1
Medium (Tier-2)	Significant workload impact, conditional path to escalation Compromise of a file server, developer workstation, or SharePoint environment enables mass data exfiltration, credential harvesting from application configs, and abuse of scoped service accounts. Escalation to tier 0 is possible but requires chaining multiple weaknesses such as finding reused credentials, misconfigured delegation, or an over-permissioned service principal.	Portal: Medium - tier 2 API: 2
Low (Tier-3)	Low blast radius, limited lateral movement potential Compromise of a standard employee workstation, guest PC, or read-only service account yields limited immediate value. An attacker gains a foothold for phishing, internal reconnaissance, or credential capture via keylogging, but cannot directly access sensitive systems or escalate without exploiting additional misconfigurations elsewhere in the environment.	Portal: Low - tier 3 API: 3

github.com/KnudsenMorten/SecurityInsight#asset-classification-identity

ClaudeChatGPT

Economic

e-economic SSO

Intempus

ArrowSphere

2linkIT

MVP

ELDK

Microsoft

PADI

LinkedIn

Messenger

Facebook

README

Contributing

MIT license

▼ Show details (expand)

Disclaimer: The asset criticality classifications and attacker-centric tiering presented here are based on my own professional judgment and experience working with identity, endpoint, and cloud security environments. Actual tier assignments may vary depending on each organization's specific architecture, hybrid connectivity model, existing compensating controls, risk tolerance, regulatory requirements, and operational priorities. Classifications should be used as a strategic prioritization framework, not as a definitive or exhaustive measure of asset risk. List is not complete.

Criticality Level	Typical Assets
Critical (Tier-0)	Entra ID Roles (built-in) – users/managed identities: Global Administrator, Privileged Role Administrator, Privileged Authentication Administrator, Partner / GDAP Delegated Admin, Directory Synchronization Accounts, Hybrid Identity Administrator (when Entra Connect is in password hash sync mode)
	Application Permissions (Graph / API): RoleManagement.ReadWrite.Directory, Directory.ReadWrite.All, AppRoleAssignment.ReadWrite.All, Policy.ReadWrite.AuthenticationMethod, PrivilegedAccess.ReadWrite.AzureAD, RoleManagement.ReadWrite.CloudPC, Organization.ReadWrite.All, Domain.ReadWrite.All, CrossTenantUserProfileSharing.ReadWrite.All, OnPremDirectorySynchronization.ReadWrite.All
	Azure Built-in Roles: Owner (root management group), User Access Administrator (root management group), Owner (tenant root subscription)
	Azure Permissions: Contributor + blueprint assign (root MG), Managed Identity Contributor (root scope), Entra ID joined device with Global Admin token cache, Subscription Owner with Az AD write federation
	AD Built-in Groups: Domain Admins, Enterprise Admins, Schema Admins, Administrators (builtin), Group Policy Creator Owners, Cert Publishers, Domain Controllers group
Immediate Domain Takeover	AD Permissions: Replication rights (DCSync), DnsAdmins (with DC write), SYSTEM on any DC
	Accounts (list not complete): krbtgt account, SYSTEM on DC, Entra Connect sync account (MSOL_), ADConnect service account, Break-glass emergency access accounts, Service accounts with DCSync rights, Accounts with AdminSDHolder propagated ACLs
	Entra ID Roles (built-in) – users/managed identities: Authentication Administrator, Hybrid Identity Administrator, Exchange Administrator, Cloud App Administrator, Application Administrator, Security Administrator, Intune Administrator, Identity Governance Administrator, External Identity Provider Administrator, B2C IFS Policy Administrator, Domain Name

github.com/KnudsenMorten/SecurityInsight#asset-classification-identity

ClaudeChatGPT

Economic

e-economic SSO

Intempus

ArrowSphere

2linkIT

MVP

ELDK

Microsoft

PADI

LinkedIn

Messenger

Facebook

README

Contributing

MIT license

4.4 Asset classification: Endpoint

[Back to top](#)

▼ Show details (expand)

Disclaimer: The asset criticality classifications and attacker-centric tiering presented here are based on my own professional judgment and experience working with identity, endpoint, and cloud security environments. Actual tier assignments may vary depending on each organization's specific architecture, hybrid connectivity model, existing compensating controls, risk tolerance, regulatory requirements, and operational priorities. Classifications should be used as a strategic prioritization framework, not as a definitive or exhaustive measure of asset risk. List is not complete.

Criticality Level	Typical Assets
Critical (Tier-0)	Server Roles: Domain Controllers (Primary/Additional), Read-Only Domain Controllers (RODC), AD CS servers (Certificate Authority — root and subordinate), Entra Connect / AD Connect servers, Federation servers (AD FS primary)
	Management: Privileged Access Workstations (PAW) used by tier 0 admins, Backup servers with DC/CA backup data, Monitoring servers with domain-level agent credentials, Key Management Services (KMS) servers with domain-joined credential store
	Infrastructure: HSM-attached servers (storing root CA private keys), SAN / storage controllers backing tier 0 VMs
	Hypervisor: Hypervisor hosts running tier 0 guest VMs (VMware ESXi, Hyper-V, KVM), vCenter / SCVMM management servers (managing tier 0 hypervisors)
	Network Equipment: Core routers (BGP, MPLS backbone), Core switches (spanning all VLANs), Firewall clusters (perimeter and internal segmentation), Out-of-band management network devices (iDRAC, iLO, IPMI), Network management servers (Cisco DNA, SolarWinds — full network write access), SD-WAN controllers, Load balancers (handling auth traffic)
Immediate full environment compromise if taken	IoT / OT: Building management systems (BMS) controllers with domain integration, Physical security controllers (badge access, CCTV management) with domain integration, OT / ICS controllers with direct network adjacency to tier 0 systems
	Server Roles: Exchange servers, MFA / RADIUS servers, PKI subordinate CA servers, DNS servers (non-DC hosted), Active Directory Federation Services (AD FS) proxy servers
	Management: Privileged Access Workstations (PAW) used by tier 1 admins, Jump servers / bastion hosts, SIEM servers, Endpoint Detection and Response (EDR) management servers

<https://github.com/KnudsenMorten/SecurityInsight#asset-classification-endpoint>
<https://github.com/KnudsenMorten/SecurityInsight#asset-classification-identity>
<https://github.com/KnudsenMorten/SecurityInsight#azure-asset-tagging>

6

Implementation - Architecture

SecurityInsight



Input - Defender XDR

Advanced Hunting via /security/runHuntingQuery (KQL)

Source table	Used by	Purpose	License
ExposureGraphNodes	all 4 engines	Master node list (5K+) + raw security context	MSEM (Defender for Servers P2 / CSPM)
ExposureGraphEdges	azure (planned)	Identity-to-resource access edges	MSEM
DeviceInfo	endpoint	Per-device inventory (OS, IPs, sensor health)	MDE P1
DeviceLogonEvents	endpoint, identity	3-day logon history for device-user-tier	MDE P2
DeviceTvmSoftwareInventory	endpoint	Installed software → 500-app catalog match	MDE P2 + Defender VM
DeviceTvmSoftwareVulnerabilities	endpoint (planned)	Per-device CVE list	MDE P2 + Defender VM
IdentityInfo	identity, endpoint	AD-synced attrs, SID↔AAD ObjectId join	Defender for Identity (MDI)
SigninLogs / AAD*SignInLogs	identity (planned)	Sign-in history (interactive + non-interactive)	Entra ID P1

Input - Microsoft Graph

Graph REST API endpoints — identity-engine inputs

Endpoint	Used by	License
/users	identity	Entra ID Free
/directory/deletedItems/microsoft.graph.user	identity	Entra ID Free + Directory.AccessAsUser.All
/servicePrincipals	identity	Entra ID Free
/groups/{id}/transitiveMembers	identity	Entra ID Free
/reports/authenticationMethods/userRegistrationDetails	identity (MFA)	Entra ID P1
/roleManagement/directory/roleAssignments	identity (perm. roles)	Entra ID Free
/roleManagement/directory/roleEligibilitySchedules	identity (PIM eligible)	Entra ID P2
/identityGovernance/privilegedAccess/group/...	identity (PIM-for-Groups)	Entra ID P2

Input - Azure & External

Azure Resource Manager / Resource Graph + non-Microsoft sources

AZURE RESOURCE MANAGER

Source	Used by	License
Azure Resource Graph (Search-AzGraph)	azure, publicip	Reader on each subscription scanned
ARM REST (management.azure.com/...)	azure	Reader on each subscription
Get-AzRoleAssignment	identity (Azure RBAC)	Reader on each subscription

EXTERNAL (NON-MICROSOFT)

Source	Used by	License
Shodan REST API (/shodan/host/{ip})	publicip	Shodan Freelancer (\$69/mo) — 1M results + 5,120 credits
Shodan REST API (/shodan/scan)	publicip (opt-in -ForceShodanRescan)	Burns 1 credit per IP

Data Model

Schema-as-source-of-truth — every column, type, source path, weight lives in JSON, not code

SCHEMA FILES

```
asset-profiles/
├── SCHEMA.json           shared vocab
├── identity.schema.json  134 fields
├── endpoint.schema.json  159 fields
├── azure.schema.json     282 fields
└── public-ip.schema.json 42 fields

asset-profiles-custom/customer overlay
└── <engine>.schema.custom.json
    (gitignored, survives upgrades)
```

THREE-LAYER MODEL

Schema

What fields enter the model

includePaths per source — explicit allow-list. No auto-include of new MS fields.

Kusto Query

How posture is detected

KQL queries + asset-metadata predicates evaluated per asset.

Catalog

How tier is assigned

500+ server-app catalog + role/permission rules → deterministic Tier 0–3.

Examples of JSON Files

Name	Date modified	Type	Size
tools	29-04-2026 23:51	File folder	
.profiles-custom-gitkeep	26-04-2026 22:27	PROFILES-CUSTO...	0 KB
azure.schema.custom.sample.json	29-04-2026 13:49	JSON File	4 KB
azure.schema.locked.json	01-05-2026 00:25	JSON File	140 KB
endpoint.schema.custom.sample.json	29-04-2026 13:49	JSON File	4 KB
endpoint.schema.locked.json	01-05-2026 08:44	JSON File	77 KB
identity.schema.custom.sample.json	29-04-2026 13:49	JSON File	4 KB
identity.schema.locked.json	01-05-2026 00:25	JSON File	77 KB
public-ip.schema.locked.json	27-04-2026 23:36	JSON File	21 KB
SCHEMA.locked.json	30-04-2026 08:31	JSON File	20 KB

Endpoint Catalog · Tiering Schema

500+ server-app catalog — JSON entries map detected software to a tier verdict

ENDPOINT-CATALOG / EXCHANGE-SERVER.JSON

```
{
  "Name": "Exchange Server",
  "Tier": 1,
  "Category": "Server Roles",
  "Reason": "Mail flow + extensive AD
privileges historically; well-known
escalation paths to DA.",
  "Detection": {
    "TvmSoftwareNames": [
      "microsoft_exchange_server*",
      "exchange_server*"
    ],
    "EgSignals": [
      "isExchangeServerDnsName",
      "isTaggedAsExchangeServer"
    ],
    "NamePatterns": [
      "(?i)^exch\\d", "(?i)^mbx\\d",
      "(?i)^cas\\d", "(?i)exchange"
    ],
    "MachineTagPatterns": [
      "(?i)exchange", "(?i)tier.?1"
    ]
  }
}
```

FIELDS

Name + Category

Human-readable role label + grouping (Server Roles, Domain Controllers, Mgmt...).

Tier

0–3 verdict assigned on match — deterministic, no ML scoring.

Reason

Audit-friendly justification — emitted into the asset's profile.

Detection — four signals

TvmSoftwareNames · MDE TVM software inventory (wildcards)

EgSignals · Exposure Graph asset markers

NamePatterns · regex on hostname

MachineTagPatterns · regex on MDE tags

Profiler Schema — Source Entry

One YAML file per (Source, Table) — engine-scoped folder

CATALOG / ENDPOINT / MDE_DEVICELOGONEVENTS.YAML

Catalog entry — one YAML per (Source, Table)

Source: MDE **Engine:** endpoint

Table: DeviceLogonEvents

Description: Logon events on managed endpoints.

Access: AdvancedHunting **LicenseRequired:** MDE-P2

LookbackWindow: 30d **JoinKey:** DeviceId

ContributesTo:

- fp_enrich

ColumnsToHarvest:

- Timestamp, DeviceId, DeviceName
- AccountName, AccountDomain, LogonType
- RemoteIP, RemoteDeviceName

ColumnPrefix: MDE_ **ConsumedBy:** Enrich

Optional Kusto pre-shape — reduces wire size.

PreShape: |

```
| where Timestamp > ago(30d)
| summarize LogonCount=count(),
    Accounts=make_set(AccountName,50)
by DeviceId
```

KEY FIELDS

Source / Engine / Table

Triple-keyed identity. File path mirrors it on disk.

ContributesTo

Names the fingerprint. Source change invalidates it & forces re-run.

ColumnsToHarvest + Prefix

Explicit allow-list. Output column = MDE_LogonCount.

ConsumedBy

Collect = metadata · **Enrich** = behaviour / external.

PreShape (optional)

KQL applied at source — shrinks wire size before harvest.

Posture Rule Schema

One YAML file per posture rule — KQL-driven, parameterized, upgrade-safe

POSTURE-RULES-CUSTOM / OT-SUBNET-TIER0.YAML

```
# Detect devices on OT (Operational Technology) network segment.
# OT devices control physical processes (PLCs, SCADA, BMS) —
# compromise = direct physical-world impact → always Tier-0.
# Lives under posture-rules-custom/ — survives GitHub upgrades.
```

```
Name: OTSubnet_Tier0
AppliesTo: endpoint
RuleType: KqlHunting
ProofLabel: AssetClass=OT-Device
ProofWeight: 95
TargetTier: 0
DataSources:
  - DeviceNetworkInfo
```

```
Parameters:
  TargetSubnetsKql: "'10.236.237.0/24'"
```

```
Query: |
let TargetSubnets = dynamic([{{TargetSubnetsKql}}]);
DeviceNetworkInfo
| where Timestamp > ago(1d)
| mv-expand parse_json(IPAddresses)
| mv-apply Subnet = TargetSubnets to typeof(string) on (
  where ipv4_is_in_range(IPAddress, Subnet))
| extend SI_PostureRule = "OTSubnet_Tier0"
```

KEY FIELDS

Name + AppliesTo + TargetTier

What gets emitted on match — engine, identifier, tier verdict.

ProofLabel + ProofWeight

Evidence written to the asset's profile + weight in the multi-signal aggregator.

Parameters

Per-tenant config — substituted into the query at runtime via `{{token}}`.

Query

Pure KQL — **no code edit** to add or change a rule.

posture-rules-custom

Custom rules survive upgrades from the locked GitHub stream.

Output Tables

Output table	Engine	DCR	Schema
SI_Identity_Profile_CL	identity	dcr-si-identity-profile	identity.schema.json (134 fields)
SI_Endpoint_Profile_CL	endpoint	dcr-si-endpoint-profile	endpoint.schema.json (159 fields)
SI_Azure_Profile_CL	azure	dcr-si-azure-profile	azure.schema.json (282 fields)
SI_PublicIP_Profile_CL	publicip	dcr-si-publicip-profile	public-ip.schema.json (42 fields)
SI_RunHealth_CL	all	dcr-si-run-health	run telemetry (counts, durations, sinks)

WORKSPACE TARGET

All 5 tables land in the Log Analytics workspace named by \$global:SI_WorkspaceResourceId.

Deployment Options

Two ways to run the pipeline — both profile the same four asset types

OPTION A

≤ 10K assets

Single-process VM

Fast in-memory cache between phases

- Single Azure VM (or container)
- All 6 phases share in-process state
- No queueing infrastructure
- Lowest latency end-to-end
- Simplest to operate & monitor

OPTION B

10K+ assets

Container Apps + KEDA

Replicas auto-scale with shard-queue depth

- Azure Container Apps + KEDA
- Staging blob between phases (parallel-replica safe)
- Per-engine shard queues
- Replicas scale 0 → N on queue depth
- Horizontal scale per asset type

Demo: Container Launch (GUI sample)

Microsoft Azure

Search resources, services, and docs (G+/-)

Copilot

2linkIT (myfamilynetwork.onmicrosoft.com)

2LINKIT (MYFAMILYNETWORK.O...)

Home

Container App Jobs

2linkIT (myfamilynetwork.onmicrosoft.com)

Identify failed Container App Jobs in my environment. List all Container App Jobs in this resource group using ARG. Filter Container App Jobs by status and location.

Create Manage view Refresh Export to CSV Open query Assign tags Add to service group Group by none

Filter for any field... Subscription equals all Resource Group equals all Location equals all Add filter

Name ↑	Type	Resource Group	Location	Subscription	
☐ caj-si-azure	...	Container App Job	rg-securityinsight	West Europe	sg-platform-sponsorship-mvp...
☐ caj-si-endpoint	...	Container App Job	rg-securityinsight	West Europe	sg-platform-sponsorship-mvp...
☐ caj-si-identity	...	Container App Job	rg-securityinsight	West Europe	sg-platform-sponsorship-mvp...
☐ caj-si-schema-discovery	...	Container App Job	rg-securityinsight	West Europe	sg-platform-sponsorship-mvp...

Showing 1 - 4 of 4. Display count: 200

Give feedback

Operations & Monitoring

Every run lands in SI_RunHealth_CL — plus live console output during execution

WHAT LANDS IN LOG ANALYTICS

SI_RunHealth_CL

RunId unique per execution

Engine identity / endpoint / azure / publicip

CollectionTime shared across all shards

Stage Schedule | Discover | Collect | Enrich | Classify |
Output | Tagging

Status OK | WARN | FAILED | SKIPPED

AssetCount in / out per stage

DurationSeconds per stage

Summary one-line human description per stage

ExtraJson discovery counts, AI cost, sink results

LIVE CONSOLE OUTPUT DURING A RUN

Element	What you see
Per-stage timing	[2/7] Discover ... 828 assets in 1 shard(s)
Per-N progress	[250/828] elapsed=8.7s hits=231 (every 50)
AI cost meter	AI=0 det=827 reused=0 err=0 ~\$0.00
Pre-ingest audit	Per-column populate %: Upn 66/828=8%
Critical-column halt	AlwaysOn col @ 0% → run aborts BEFORE ingest
Friendly auth banner	CONNECTED OK — METHOD: ServicePrincipal

Operations & Monitoring

Three queries' operators run against SI_RunHealth_CL

LAST 10 RUNS ACROSS ALL ENGINES

```
SI_RunHealth_CL | where TimeGenerated > ago(7d)
| summarize arg_max(TimeGenerated, *) by RunId
| project CollectionTime, Engine, Status, AssetCount, DurationSeconds, Summary
| order by CollectionTime desc | take 10
```

ENGINES THAT HAVEN'T RUN IN 24H · ALERT CANDIDATE

```
SI_RunHealth_CL
| where Stage == 'Output'
| summarize LastRun = max(CollectionTime) by Engine
| where LastRun < ago(24h)
```

AI SPEND ROLLUP — LAST 30 DAYS · COST GUARDRAIL

```
SI_RunHealth_CL
| where Stage == 'Classify' and TimeGenerated > ago(30d)
| extend cost = todouble(parse_json(ExtraJson).AiSpent)
| summarize TotalAiSpend = sum(cost) by Engine
```

Hash Bucketing

PROBLEM & SOLUTION

Problem

Microsoft Graph `/security/runHuntingQuery` silently truncates when row count × payload exceeds an internal cap. Hard limit of 30000 rows

Solution

Split a label-wide query into N sub-queries via `hash_djb2(NodeId) % N`. Each bucket returns ≤ 30K rows so the response stays under the cap.

Adaptive

Count probe per label: ≤30K → 1 query; >30K → `ceil(count / 30K)` buckets. Tunable via `$global:SI_EgIdentityBucketThreshold`.

KQL PATTERN

ExposureGraphNodes

```
| where NodeLabel == 'serviceprincipal'  
| extend _bucket = hash_djb2(NodeId) % 4  
| where _bucket == 0  
| project NodeId, NodeLabel, NodeName,  
           EntityIds, NodeProperties
```

→ Run buckets 0..N-1, union results

Shard Sizing (staging)

STAGE DISCOVER OUTPUT

Problem

Blob round-trip cost dominates for many small shards; one huge shard kills parallelism.

Solution

2,000 records per
`staging/<runid>/<stage>/replica-
NNN/shard-NNNNN.jsonl`

→ Each replica writes/reads *ONLY* its own replica-
NNN/ prefix → zero contention.

SHARD-COUNT BY TENANT SIZE

Tenant size	Shard count	Notes
< 2K assets	1	Single-shard, fits in 1 file
2K - 10K	2 - 5	Parallel-replica ready
10K - 50K	5 - 25	Each replica handles 1+ shards
50K +	25+	Split tenants by subscription/MG

KEDA Queue Auto-Scale – Container

KEDA = Kubernetes Event-Driven Autoscaling — Azure Container Apps' built-in scaler. Watches an external signal (Storage Queue depth) and adjusts replica count automatically.

QUEUE-DEPTH SCALING (CONTAINER APPS)

Stage Discover



KEDA queue scaler



N container replicas wake up — each pulls 1 shard, processes it

*enqueue 1 msg per shard
→ si-<engine>-collect queue*

*replica = ceil(queueDepth / N)
min = 0 (idle = \$0 compute)
max = 30 (configurable)*

OUTCOMES

Idle = \$0

Replicas scale to zero between runs — no warm-pool cost.

Burst = parallel

30 replicas spin up for a 60K-asset tenant — finish in the same wall-clock as 2K.

No tuning per tenant

Same KEDA config handles 200 assets and 200,000.

Fingerprint Cache (vs -ForceFullRun)

SIFINGERPRINT (AZURE TABLE)

One row per AssetId, partition by engine — survives between runs.

AssetId entra-user:... / mde:... / ip:..

Engine identity / endpoint / azure / publicip

LastSeen CollectionTime of last touch

LastClassifiedAt when Classify produced verdict

CachedTier 0–3 — picks cadence

CachedVerdict last SI_Verdict string

CachedServiceType fallback if Classify skipped

CollectHash SHA256 from last full Classify

EnrichHash, **PostureHash**, per-stage change-detection

ClassifyHash

WHAT THE CACHE ENABLES

Capability	How it works
Cadence skip	If now – LastClassifiedAt < cadenceFor(CachedTier) → emit cached verdict, skip Enrich + Classify
Tier-aware scheduling	Schedule reads CachedTier per asset → applies T0=12h / T1=24h / T2=72h / T3=168h cadence
Cold-start handling	New asset = no row → falls into _default=24h, gets classified on first encounter
Force re-baseline	-ForceFullRun bypasses ALL cache lookups (use after rule/prompt change)
Cross-run audit	Diff cached hash vs current run → answers "what changed since Monday" without N snapshots

Per-Stage Hashing

Every row carries 4 SHA-256 hashes — one per pipeline stage. Powers work-skip + change detection.

Hash	Computed over	Used for
CollectHash	All collect-stage fields (identity, correlation, lifecycle, posture, attribution)	"Has this asset's raw posture changed since last run?"
EnrichHash	All enrich-stage fields	"Did EG enrichment / cross-engine joins change?"
PostureHash	All posture-rule outcomes	"Did any posture rule flip?"
ClassifyHash	All classify-stage fields	"Did the tier verdict actually move?"

Per-Tier Scheduling - Net Effect

TIER → CADENCE

T0 immediate-compromise risk **every 12h**

T1 high blast radius **every 24h**

T2 limited blast radius **every 72h (3d)**

T3 low / default **every 168h (7d)**

_default unclassified yet **every 24h**

Stage Collect reads cached tier + last-classified time → "still within window? skip"

→ asset never reaches

Enrich/Classify/Output this run.

WORKED EXAMPLE — 100K-ASSET TENANT

~5% T0/T1 re-classify daily · ~25% T2 every 3 days · ~70% T3 weekly

Average daily volume: ~12K (not 100K)

8× less compute than naive everyone-every-day.

How the 6 layers compose

80K identity nodes → 4 buckets/label → 40 shards × 2K → 20 KEDA replicas → cache skip drops to 12K → hash skip ~600 changed → T0 fast-lane 800.

Result: ~6 min wall-clock, ~\$0.08 compute

(Container Apps consumption-based pricing.)

Interested ?

How can I implement this in my environment ?

- ◆ Github:

- ◆ <https://github.com/KnudsenMorten/SecurityInsight>

- ◆ Quick-link:

- ◆ **securityinsight.mortenknudsen.net**

(url forward to Github repo)





Microsoft Israel (May 2022) | Microsoft Defender Vulnerability Management & Secure Score Principal Group PM



Azure Resource Graph and Azure Resource Management PMs



ExposureGraph PM, Shirley Kochavi, March 2026, Meeting Redmond, USA



Some people in this chat are outside your org. It's possible they have message-related policies that will apply to the chat. [Learn more](#)

Raviv Tamir added Israel Aloni and Morten Waltrorp Knudsen to the chat.

Raviv Tamir 09-03 10:38

RT Hello Morten. hope you had time to rest after the great event.

09-03 10:38

yes, thx

Raviv Tamir 09-03 10:38

RT We are doing some work on exposure management strategy and would love to pick your brains

Microsoft Vice President, Raviv Tamir reached out (March 2026)

Re: [EXT] Re: Issue: Missing data in ExposureGraph

Lior Arviv <liorav@microsoft.com>
To: Morten Waltrorp Knudsen; Maayan Waknine; Adi Shua Zucker
Cc: Noy Aizenberg; Shirley Kochavi

Start your reply all with: [Thank you. I appreciate that.](#) [You are welcome.](#) [Sounds good, thank you.](#) [Feedback](#)

Thank you for the confirmation, Morten. I apologize for any inconvenience this issue may have caused. We are committed to continuously improving our monitoring processes and will investigate how to prevent such issues in the future. Again, thank you for your collaboration. We will begin rolling out the fix to all tenants.

Best,
Lior

I found a critical bug in Graph. Hotfix will be deployed to all tenants worldwide (Feb 2026)



What You Need to Run SecurityInsight



Microsoft Defender XDR

Source of advanced hunting tables and Exposure Graph — DeviceLogonEvents, IdentityInfo, ExposureGraphNodes/Edges



Azure OpenAI

GPT-4o (or PTU) for identity permission/role tiering, app mapping and exposure synthesis



Microsoft Entra ID

Identity source — groups, directory roles (incl. PIM), Graph API permissions, Azure RBAC assignments



Azure Subscription

Hosts Log Analytics workspace, Container Apps Job, Table Storage cache, Key Vault and managed identity



PowerShell 7 Runtime

Runtime for the scan orchestrator and pipeline modules — Az modules, parallel runspaces, throttle-aware REST



Service Principal & Permissions

Defender Reader, Log Analytics Reader (cross-workspace), Reader on tagged subs, Sentinel Contributor on the SI workspace

License Shopping List

What unlocks each engine — minimum vs. recommended

Engine	Minimum (end-to-end) Limited Risk Analysis capabilities	Recommended (full coverage) Full Risk Analysis capabilities
Identity	Entra ID Free (skips PIM, MFA, MDI)	Entra ID P2 + MDI (E3 with E5 Sec or E5 or E7)
endpoint	MDE P1 (basic inventory)	MDE P2 (E3 with E5 Sec or E5 or E7)
azure	Azure Reader on each subscription Contributor on LogAnalytics workspace	Defender for Cloud
publicip	Shodan subscription <i>Future: REST api support – more 😊</i>	Shodan subscription <i>Future: REST api support – more 😊</i>

Get Involved - three ways to make this better

Open source. Built to be improved by the community that runs it.

01



Download & Test

Clone the repo, run it against your tenant, see your assets tiered in minutes.

Zero-touch - no tags, no writes, nothing changes on your assets.

CLONE → RUN → REVIEW

02



Contribute Knowledge

Add a posture rule, a YAML KQL detection, or an exposure-catalog entry.

Open a pull request — every merged contribution sharpens the tier model for everyone.

OPEN A PR

03



Solution Feedback

Found a bug? Got an idea for a new engine, sink, or report?

File an issue — bug reports and feature requests both shape the roadmap.

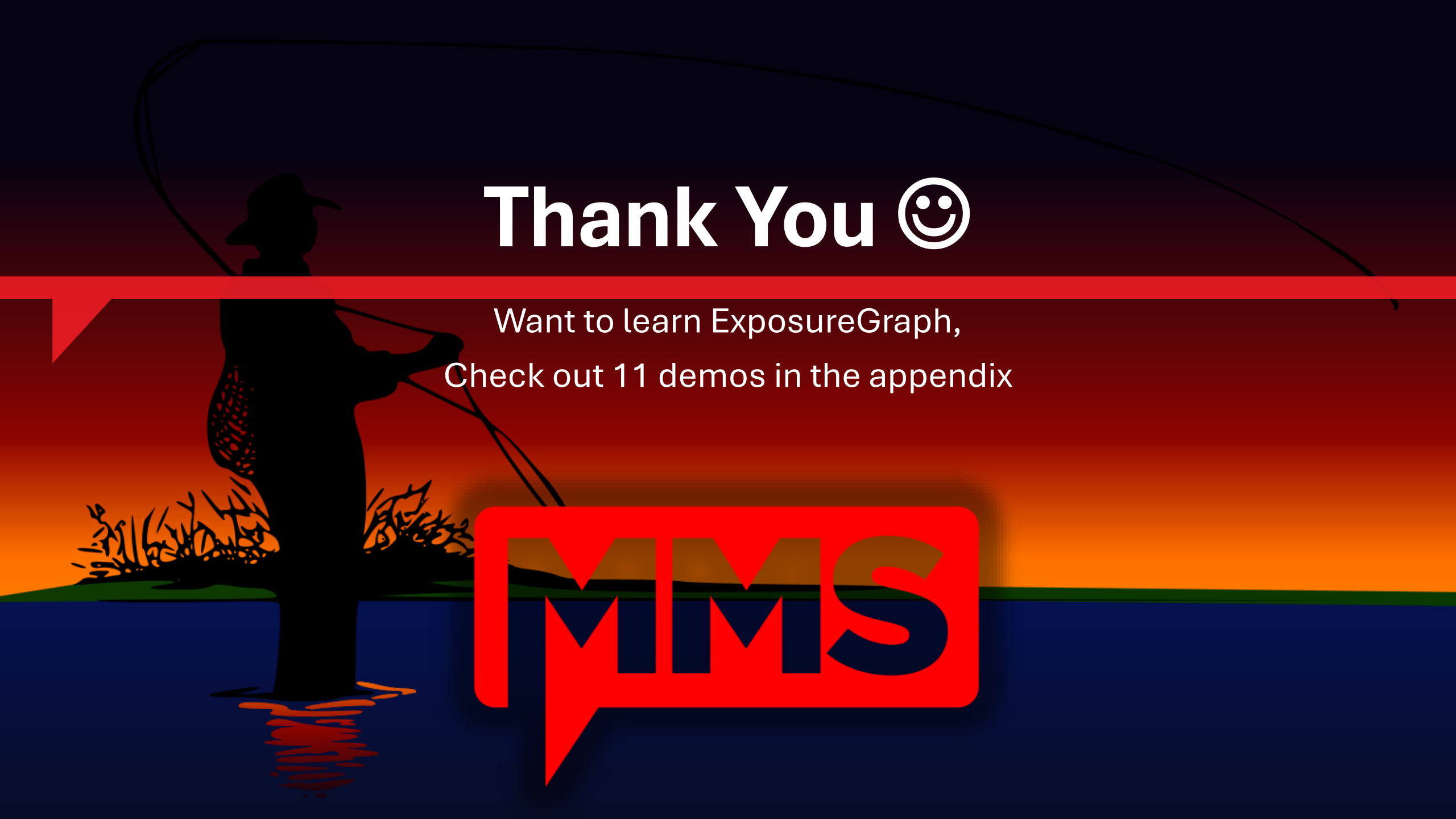
FILE AN ISSUE

github.com/KnudsenMorten/SecurityInsight

Download Presentation with all demo's



<https://sharing.mortenknudsen.net/Rethinking-Security-Prioritization-in-Defender-A-Tiered-Risk-Score-Approach-MMSMOA2026.pptx>



Thank You 😊

Want to learn ExposureGraph,
Check out 11 demos in the appendix



Extended Q&A



Recast



ninjaOne®



numecent®



Let's connect - Morten Knudsen



/in/knudsenmorten



@mortenknudsen.net



@knudsenmortendk



aka.ms/morten



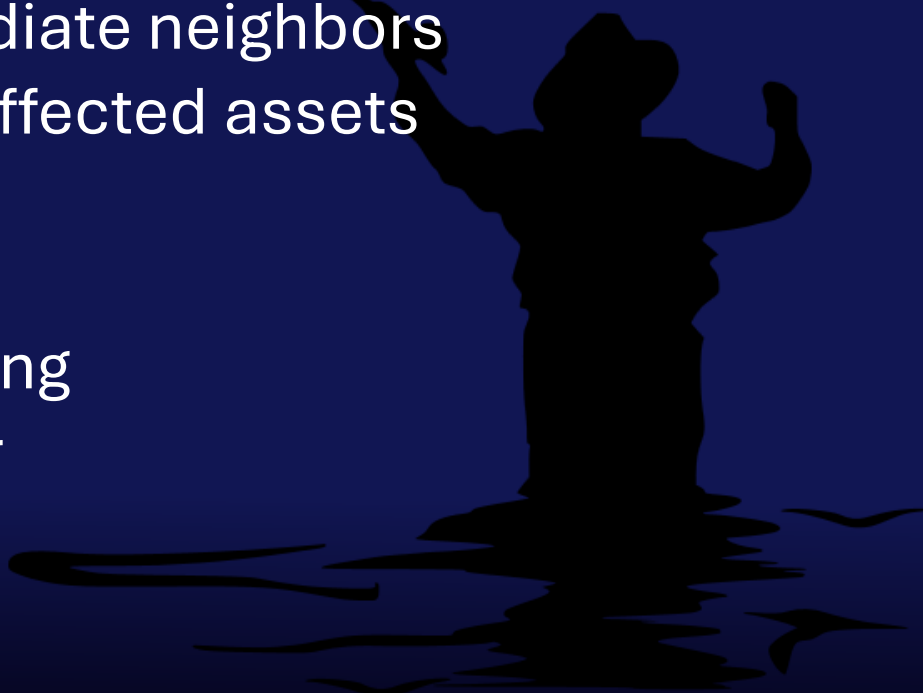
mok@mortenknudsen.net

LinkedIn



Querying ExposureGraph

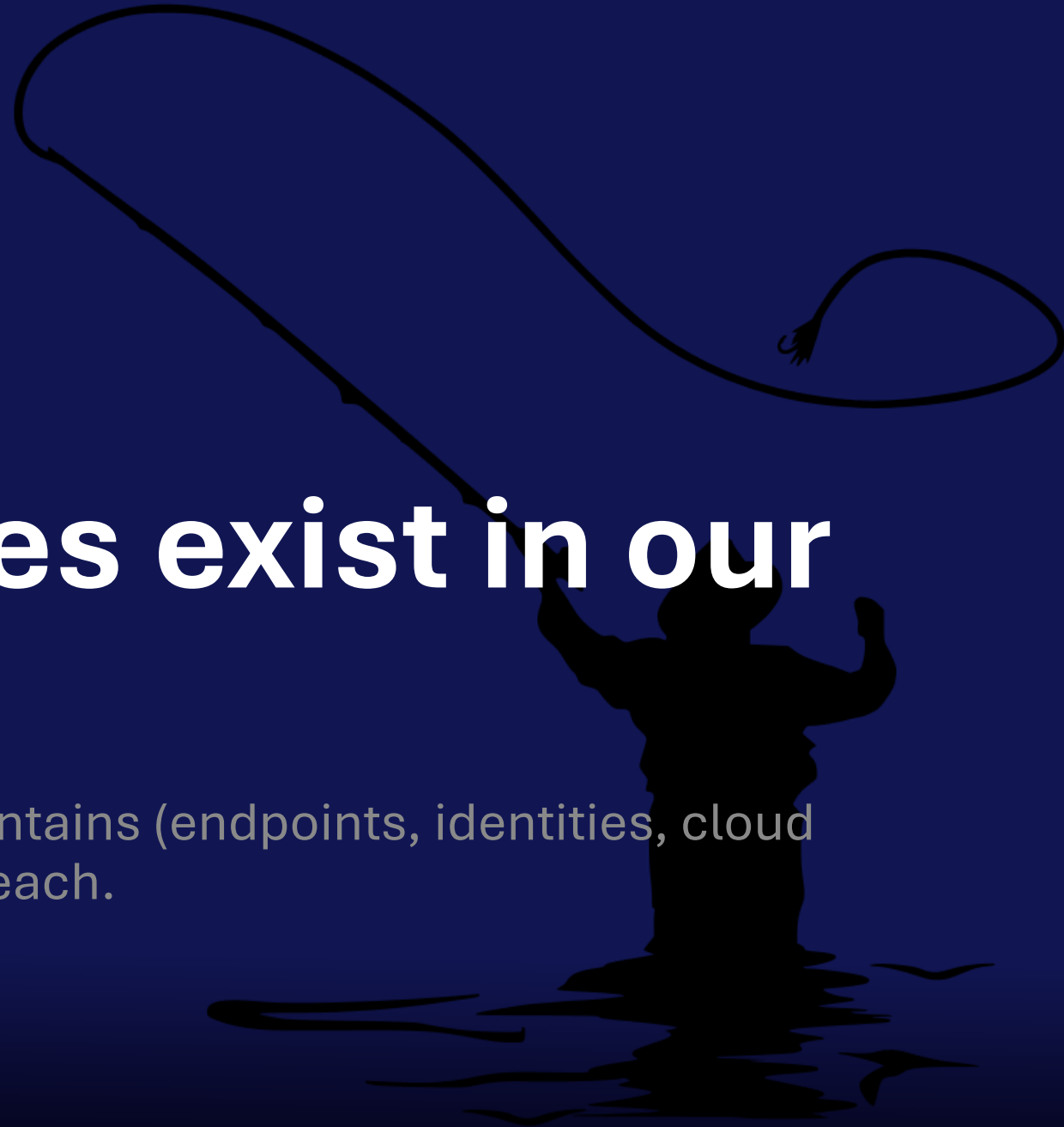
- ◆ Demo 1: What asset types exist in our exposure graph
- ◆ Demo 2: List endpoints and their criticality (asset posture view)
- ◆ Demo 3: What edge labels exist
- ◆ Demo 4: Show relationship between node types
- ◆ Demo 5: Pick one asset and show its immediate neighbors
- ◆ Demo 6: Find all “finding” nodes and their affected assets
- ◆ Demo 7: Internet exposure risk factor
- ◆ Demo 8: Internet-facing assets
- ◆ Demo 9: Assets impacted by the same finding
- ◆ Demo 10: Show all Edges for a specific user
- ◆ Demo 11: Excluded assets hygiene check



Demo 1:

What asset types exist in our exposure graph

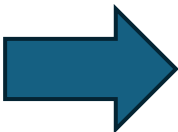
Show what kinds of objects the graph contains (endpoints, identities, cloud resources, apps, etc.) and how many of each.



ExposureGraphNode

| summarize NodeCount = count() by NodeLabel

| order by NodeCount desc



NodeLabel	NodeCount
> mdcSecurityRecommendation	484350
> Cve	342818
> group	3402
> serviceprincipal	1018
> baseModel	979
> managedidentity	553
> Microsoft Entra OAuth App	236
> mdcManagementRecommendation	209
> mdcAuditingRecommendation	88
> resourcegroups	78
> user	71
> device	54
> microsoft.compute/virtualmachines/exten:	40
> mde-healthFinding	27
> githubrepository	26

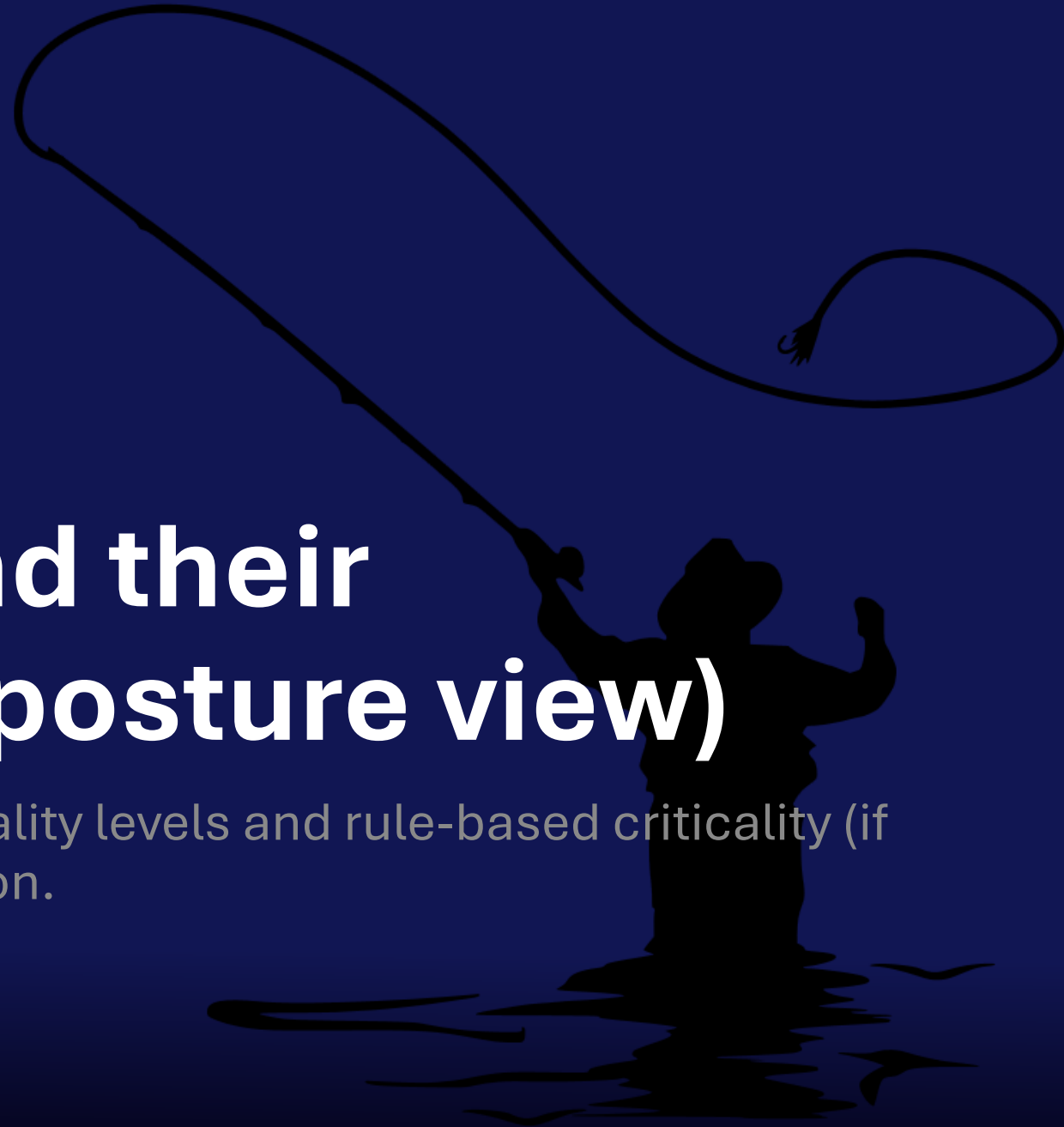
Process:

- 1) Query nodes
- 2) Use NodeLabel to group into “types”

Demo 2:

List endpoints and their criticality (asset posture view)

Show “asset context” enrichment: criticality levels and rule-based criticality (if populated), plus basic asset identification.



ExposureGraphNode

```
| where toString(NodeProperties.rawData.deviceCategory) == "Endpoint"  
| extend CriticalityLevel = toint(coalesce(  
  toString(NodeProperties.criticalityLevelProps[0].criticalityLevel),  
  toString(NodeProperties.rawData.criticalityLevel.criticalityLevel),  
  toString(NodeProperties.criticalityLevel.criticalityLevel)  
))  
| extend RuleBasedCriticality = toint(coalesce(  
  toString(NodeProperties.criticalityLevelProps[0].ruleBasedCriticalityLevel),  
  toString(NodeProperties.rawData.criticalityLevel.ruleBasedCriticalityLevel),  
  toString(NodeProperties.criticalityLevel.ruleBasedCriticalityLevel)  
))  
| project NodeId, AssetName=NodeName, NodeLabel, CriticalityLevel, RuleBasedCriticality, NodeProperties  
| order by CriticalityLevel asc
```

Process:

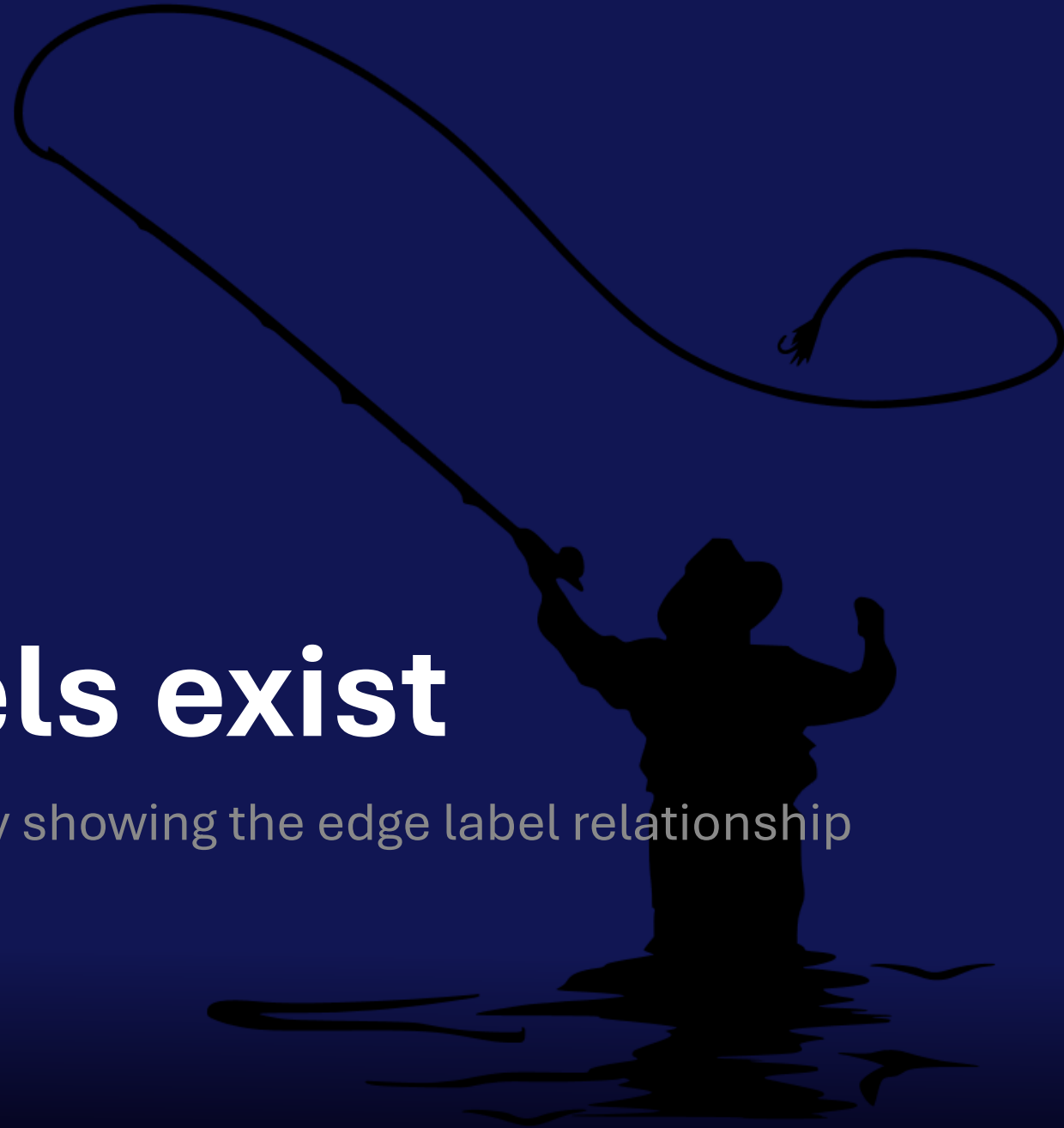
- 1) Filter to endpoint assets (many tenants store this in rawData.deviceCategory)
- 2) Extract criticality fields from the possible locations
- 3) Sort by most critical first

☐ Nodeld  	AssetName  	NodeLabel  	CriticalityLevel  	RuleBasedCriticality  	NodeProperties  
☐ > f95d2e35601544b9b0c7125d77ca4c	eps-demo-byod	microsoft.compute/virtualmachines			{"rawData":{"deviceRole":[],"lastSeen":"2026-04
☐ > 230f7bc7524b4ecc9ba429a27a9846	eps-demo-dc1	microsoft.compute/virtualmachines			{"rawData":{"deviceCategory":"Endpoint","devic
☐ > 885afcb1c4f147b78b3c1c7378e0bd	demowin2	microsoft.compute/virtualmachines			{"rawData":{"deviceSubtype":"Server","isHybrid
☐ > 7fae4100b5a241df8ea4bd227a35d9	eps-demo-whfb	microsoft.compute/virtualmachines			{"rawData":{"deviceType":"Workstation","isCust
☐ > 6fa35b325acc445ca8b04a3ae400bc		device			{"rawData":{"osVersion":"6.0","firstSeenByInven
☐ > fd176dca37f247e8a81c3642d499ba	MACBOOKAIR-2A42	device			{"rawData":{"deviceCategory":"Endpoint","devic
☐ > 1fe344af097b474e9dbf1eac39f734c	dc1.2linkit.local	microsoft.compute/virtualmachines	0	0	{"rawData":{"tags":{"tags":{"Environment":"PRO
☐ > f601b610bc88400baf86becda53f39	dc3.2linkit.local	microsoft.compute/virtualmachines	0	0	{"rawData":{"tags":{"tags":{"Environment":"PRO
☐ > 7d4f6d2ec54b426ea8e4e95f8e3578	mgmt1.2linkit.local	microsoft.compute/virtualmachines	0	0	{"rawData":{"tags":{"tags":{"Environment":"PRO
☐ > cd9b95e12ac849dfb1ae93d3675c1e	strv-mok-dt-03	device	1	1	{"rawData":{"deviceCategory":"Endpoint","devic
☐ > 69e43cfad61c4f9e883f0e40303aa36	strv-cew-lt-03	device	2	2	{"rawData":{"isCustomerFacing":true,"deviceTyp
☐ > 9be56ff4cdf94f15b298562eb4b02f7	niels_Android	device	2	2	{"rawData":{"isCustomerFacing":true,"deviceTyp
☐ > 585e4d2679e346178a7866452e40fc	heim-new-lt-02	device	2	2	{"rawData":{"isCustomerFacing":true,"deviceTyp
☐ > b24a984cdc9b40d5948013fa60c79e	strv-mew-lt-02	device	2	2	{"rawData":{"deviceCategory":"Endpoint","devic
☐ > fe32fb6232354f8b8e7c63e946876ce	dons-ekn-lt-02	device	2	2	{"rawData":{"isCustomerFacing":true,"deviceTyp

Demo 3:

What edge labels exist

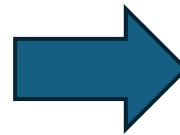
Show how the graph connects objects by showing the edge label relationship taxonomy



ExposureGraphEdges

| summarize EdgeCount = count() by EdgeLabel

| order by EdgeCount desc



Process:

1) Query edges

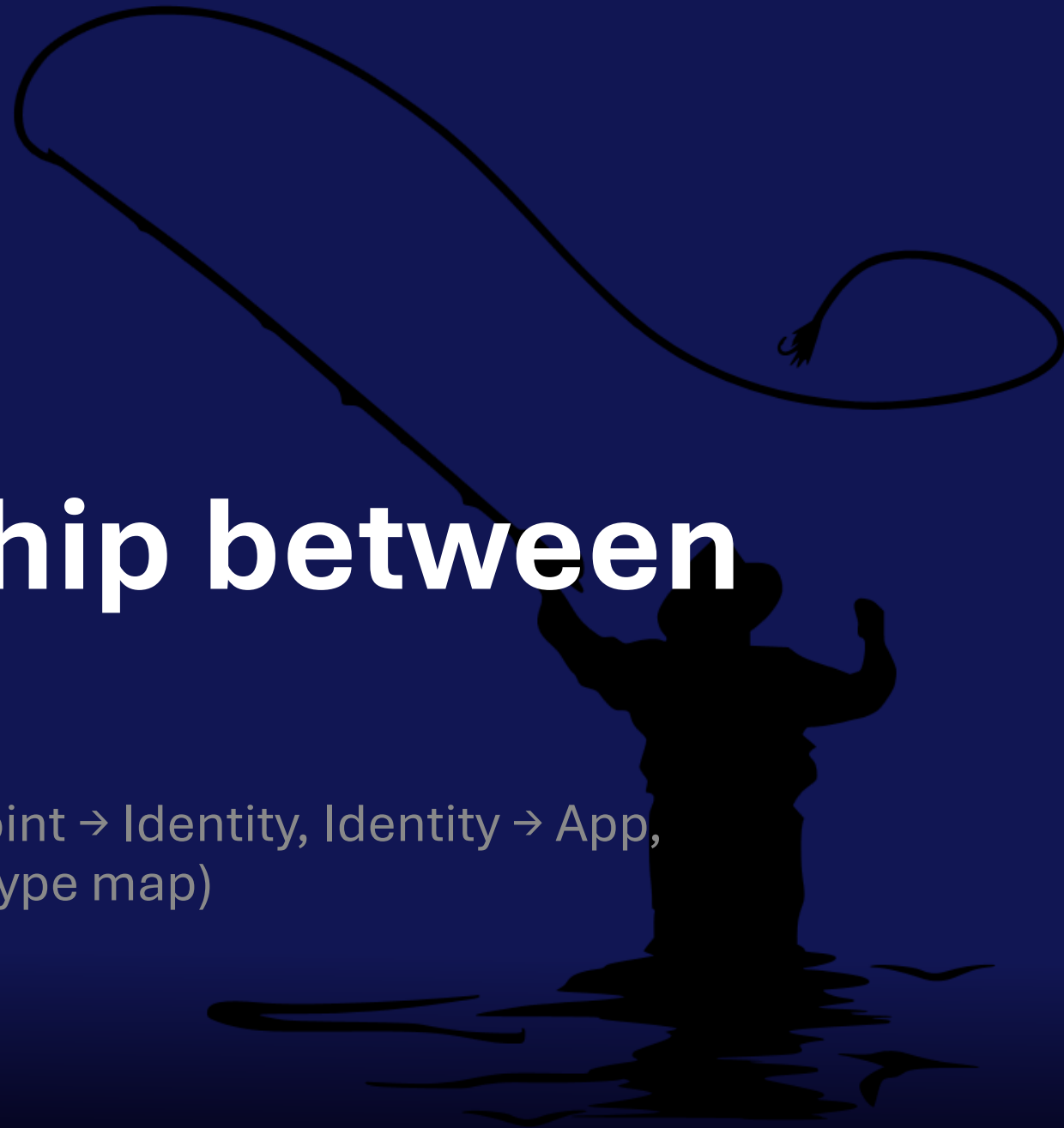
2) Group by EdgeLabel

☐	EdgeLabel	EdgeCount
☐	> affecting	4939
☐	> has permissions to	1414
☐	> member of	1373
☐	> has role on	1018
☐	> can authenticate as	239
☐	> contains	226
☐	> can authenticate to	40
☐	> routes traffic to	38
☐	> can impersonate as	32
☐	> has credentials of	15
☐	> frequently logged in by	12
☐	> runs on	7
☐	> defined in	1
☐	> defines	1

Demo 4:

Show relationship between node types

Show a relationship heat map like Endpoint → Identity, Identity → App, CloudResource → Finding, etc. (type-to-type map)



```
let Nodes = ExposureGraphNodes | project NodeId, NodeLabel, NodeName;  
ExposureGraphEdges  
| join kind=inner (Nodes) on $left.SourceNodeId == $right.NodeId  
| extend SourceLabel = NodeLabel, SourceName = NodeName  
| join kind=inner (Nodes) on $left.TargetNodeId == $right.NodeId  
| extend TargetLabel = NodeLabel, TargetName = NodeName  
| summarize EdgeCount=count() by SourceLabel, EdgeLabel, TargetLabel  
| order by EdgeCount desc
```

Process:

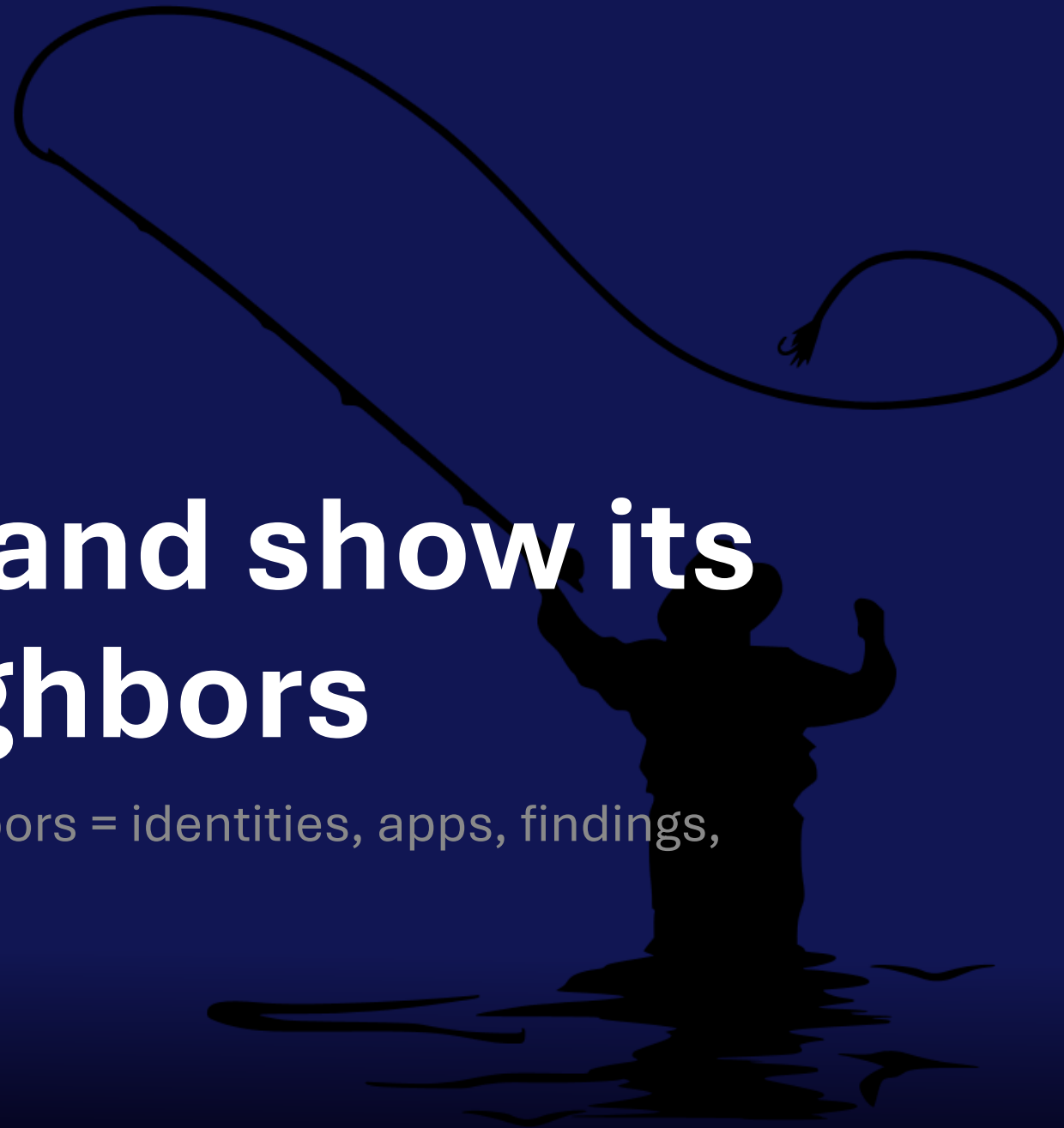
- 1) Join edges to nodes twice (source and target)
- 2) Summarize by SourceLabel → EdgeLabel → TargetLabel

☐ SourceLabel  	EdgeLabel  	TargetLabel  	EdgeCount 
☐ > Cve	affecting	Cve	4764
☐ > user	member of	user	1250
☐ > group	has role on	group	807
☐ > managedidentity	has permissions to	managedidentity	675
☐ > serviceprincipal	has permissions to	serviceprincipal	647
☐ > Microsoft Entra OAuth App	can authenticate as	Microsoft Entra OAuth App	214
☐ > managedidentity	has role on	managedidentity	105
☐ > group	member of	group	103
☐ > mdcSecurityRecommendation	affecting	mdcSecurityRecommendation	94
☐ > user	has permissions to	user	90
☐ > subscriptions	contains	subscriptions	78
☐ > resourcegroups	contains	resourcegroups	65
☐ > user	has role on	user	63
☐ > aadSecurityRecommendation	affecting	aadSecurityRecommendation	51
☐ > serviceprincipal	has role on	serviceprincipal	42

Demo 5:

Pick one asset and show its immediate neighbors

Show neighbors to a single asset (neighbors = identities, apps, findings, resources)



```
let assetSearch = "mgmt1.2linkit.local";
```

```
let Nodes = ExposureGraphNodes | project NodeId, NodeLabel, NodeName;
```

```
let Asset = Nodes | where NodeName has assetSearch | take 1;
```

```
let AssetId = toscalar(Asset | project NodeId);
```

```
ExposureGraphEdges
```

```
| where SourceNodeId == AssetId or TargetNodeId == AssetId
```

```
| extend NeighborId = iif(SourceNodeId == AssetId, TargetNodeId, SourceNodeId)
```

```
| join kind=leftouter (Nodes) on $left.NeighborId == $right.NodeId
```

```
| project AssetId, EdgeLabel, NeighborLabel=NodeLabel, NeighborName=NodeName, NeighborId
```

```
| order by NeighborLabel asc, NeighborName asc
```

Process:

- 1) Pick an asset name (or NodeId)
- 2) Get all edges where it's source or target
- 3) Join to nodes to show neighbor names/types

AssetId  	EdgeLabel  	NeighborLabel  	NeighborName  	NeighborId  
 /d4f6d2ec54b426ea	affecting	Cve	CVE-2026-25188	930771d757b244fca53bd54544778114
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-25189	cacd4ecd686b4da785e30bc8e652662c
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-25190	7733441bef6c4b1bbe36897c3969a9d6
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-25926	4da106be14154c808548d2b8835c1e48
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-26111	3c0423f4f8b7470990969ddbb9a3488a
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-26128	1b5ace65cc67409a8094ed595452a3c0
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-26130	1c5cd19f3daa4641ac4034c0567ff4aa
 7d4f6d2ec54b426ea	affecting	Cve	CVE-2026-26132	ec9673866975416dba9377bcfbcb29064
 7d4f6d2ec54b426ea	contains	azure-active-directory-user-credentials	1cf7e0aab6ac02f53037913631665a1c	c525c8b0781a41759a40549cad44c47c
 7d4f6d2ec54b426ea	contains	azure-database-connection-string	2dea1a426b0e0f029d00ecd5653670c	7e0ea16a5b7948378b1066752e49d927
 7d4f6d2ec54b426ea	contains	azure-storage-connection-string	419367600c6bb171e43c2acae0cc1bc	accec3f1aa73e4c338de46b1937621c7d
 7d4f6d2ec54b426ea	contains	azure-storage-connection-string	609fce4dccdc9046f9baa8b14cd2896	8428e789d2ca4018be9c88a8226e7483
 7d4f6d2ec54b426ea	contains	azure-storage-shared-access-signature	162cbca5843ab8132f7b0456117f155	64e1c467908a4ca092ddc13497b3fba6
 7d4f6d2ec54b426ea	contains	azure-storage-shared-access-signature	34f1d038fa6012652d919f802a62ab2	138971078d534290ada3f1ecd4feadbd
 7d4f6d2ec54b426ea	contains	azure-storage-shared-access-signature	7bbda8c3aac90af89db737ac43e0b92	b09b5e82db0d4211a34c1d555ec39fb8
 7d4f6d2ec54b426ea	contains	azure-storage-shared-access-signature	f10b773933564c945da87ec7ef8dc57	c4cc64865ac84ddd9169a1dff84ca54e

Demo 6:

Find all “finding” nodes and their affected assets

Show that findings are nodes and they connect to impacted assets via edges (often “affecting...”)

```
let Findings =  
  ExposureGraphNodes  
  | where toString(Categories) has "finding"  
  | project FindingNodeId=NodeId, FindingName=NodeName, FindingLabel=NodeLabel;  
  
let Nodes = ExposureGraphNodes | project NodeId, NodeName, NodeLabel;  
  
ExposureGraphEdges  
| where toString(EdgeLabel) has "affecting"  
| join kind=inner (Findings) on $left.SourceNodeId == $right.FindingNodeId  
| join kind=inner (Nodes) on $left.TargetNodeId == $right.NodeId  
| summarize ImpactedAssets=dcount(NodeId) by FindingName, FindingLabel  
| order by ImpactedAssets desc
```

Process:

- 1) Identify findings (Categories contains "finding")
- 2) Join to edges labeled affecting
- 3) Join targets/sources to get impacted assets
- 4) Summarize counts

☐		FindingName  	FindingLabel  	ImpactedAssets
☐	>	SigninRiskPolicy	aadSecurityRecommendat	28
☐	>	MfaRegistrationV2	aadSecurityRecommendat	15
☐	>	CVE-2025-68160	Cve	14
☐	>	CVE-2026-22795	Cve	14
☐	>	CVE-2025-69419	Cve	14
☐	>	CVE-2025-9230	Cve	14
☐	>	CVE-2025-69420	Cve	14
☐	>	CVE-2026-22796	Cve	14
☐	>	CVE-2025-69421	Cve	14
☐	>	CVE-2025-15467	Cve	14
☐	>	CVE-2025-15468	Cve	13
☐	>	CVE-2025-66199	Cve	13
☐	>	CVE-2025-9231	Cve	13
☐	>	CVE-2025-9232	Cve	12
☐	>	CVE-2024-9143	Cve	10

Demo 7:

Internet exposure risk factor

Demonstrate that edges can carry risk metadata (riskLevel, riskFactors) - > Risk is not just on a device, it's on relationships !!



```
let Nodes = ExposureGraphNodes | project NodeId, NodeName, NodeLabel;
```

ExposureGraphEdges

```
| extend EdgeProps = column_ifexists("EdgeProperties", dynamic({}))
```

```
| extend RiskLevel = toString(EdgeProps.rawData.risk.riskLevel)
```

```
| extend RiskFactors = toString(EdgeProps.rawData.risk.riskFactors)
```

```
| where RiskFactors has "Exposure to the Internet" or tolower(RiskLevel) == "critical"
```

```
| join kind=leftouter (Nodes) on $left.SourceNodeId == $right.NodeId
```

```
| extend SourceName=NodeName, SourceLabel=NodeLabel
```

```
| join kind=leftouter (Nodes) on $left.TargetNodeId == $right.NodeId
```

```
| extend TargetName=NodeName, TargetLabel=NodeLabel
```

```
| project EdgeLabel, RiskLevel, RiskFactors, SourceLabel, SourceName, TargetLabel, TargetName
```

```
| order by RiskLevel desc
```

Process:

- 1) Start from edges
- 2) Pull EdgeProperties.rawData.risk.*
- 3) Filter on "Exposure to the Internet"
- 4) Show which assets are affected

Filters: Add filter

☐ EdgeLabel	RiskLevel	RiskFactors	SourceLabel	SourceName	TargetLabel	TargetName
☐ > affecting	Medium	["Exposure to the Internet'	mdcSecurityRecommendat	[Enable if required] Storage accounts shoulc	mdcSecurityRecommendat	[Enable if required] Storag
☐ > affecting	Medium	["Exposure to the Internet'	mdcSecurityRecommendat	Virtual machines and virtual machine scale s	mdcSecurityRecommendat	Virtual machines and virtu
☐ > affecting	Medium	["Exposure to the Internet'	mdcSecurityRecommendat	Windows virtual machines should enable Az	mdcSecurityRecommendat	Windows virtual machines
☐ > affecting	Medium	["Exposure to the Internet'	mdcSecurityRecommendat	Managed identity should be enabled on we	mdcSecurityRecommendat	Managed identity should l
☐ > affecting	Medium	["Exposure to the Internet'	mdcSecurityRecommendat	[Enable if required] Storage accounts shoulc	mdcSecurityRecommendat	[Enable if required] Storag
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	[Enable if required] Microsoft Foundry resol	mdcSecurityRecommendat	[Enable if required] Micros
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Microsoft Foundry resources should restrict	mdcSecurityRecommendat	Microsoft Foundry resourc
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Access to storage accounts with firewall anc	mdcSecurityRecommendat	Access to storage account
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Microsoft Foundry resources should use Azi	mdcSecurityRecommendat	Microsoft Foundry resourc
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Microsoft Foundry resources should use Azi	mdcSecurityRecommendat	Microsoft Foundry resourc
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Storage accounts should restrict network ac	mdcSecurityRecommendat	Storage accounts should r
☐ > affecting	Low	["Exposure to the Internet'	mdcSecurityRecommendat	Microsoft Foundry resources should use Azi	mdcSecurityRecommendat	Microsoft Foundry resourc
☐ > affecting	Low	["Exposure to the Internet'	mdcAuditingRecommendat	Diagnostic logs in Microsoft Foundry resour	mdcAuditingRecommendat	Diagnostic logs in Microsc
☐ > affecting	Low	["Exposure to the Internet'	mdcAuditingRecommendat	Diagnostic logs in Microsoft Foundry resour	mdcAuditingRecommendat	Diagnostic logs in Microsc
☐ > affecting	Low	["Exposure to the Internet'	mdcAuditingRecommendat	Diagnostic logs in Microsoft Foundry resour	mdcAuditingRecommendat	Diagnostic logs in Microsc

Demo 8:

Internet-facing assets

(Customer-facing)

Show how you can segment assets by business impact flags like customer-facing and then look at their top exposures.



```
let CustomerFacingAssets =  
  ExposureGraphNodes  
  | extend IsCustomerFacing = tobool(coalesce(NodeProperties.rawData.isCustomerFacing, NodeProperties.raw.isCustomerFacing))  
  | where IsCustomerFacing == true  
  | project AssetNodeId=NodeId, AssetName=NodeName, AssetLabel=NodeLabel;  
  
let Nodes = ExposureGraphNodes | project NodeId, NodeName, NodeLabel;  
  
ExposureGraphEdges  
| extend EdgeProps = column_ifexists("EdgeProperties", dynamic({}))  
| extend RiskLevel = toString(EdgeProps.rawData.risk.riskLevel)  
| join kind=inner (CustomerFacingAssets) on $left.SourceNodeId == $right.AssetId  
| join kind=leftouter (Nodes) on $left.TargetNodeId == $right.NodeId  
| summarize EdgeCount=count(), CriticalEdges=countif(tolower(RiskLevel) in ("critical","very high"))  
  by AssetName, AssetLabel, EdgeLabel, TargetLabel=NodeLabel  
| order by CriticalEdges desc, EdgeCount desc
```

Process:

- 1) Filter nodes to assets where isCustomerFacing = true
- 2) Join to edges and risk metadata
- 3) Rank the “most risky customer-facing relationships”

☐	AssetName  	AssetLabel  	EdgeLabel  	TargetLabel  	EdgeCount  	CriticalEdges
☐	> dc1.2linkit.local	microsoft.compute/virtuali	contains	azure-app-configuration-k	5	0
☐	> mgmt1.2linkit.local	microsoft.compute/virtuali	contains	azure-storage-shared-acc	4	0
☐	> strv-mok-dt-03	device	contains	entra-userCookie	3	0
☐	> strv-acw-dt-03	device	contains	entra-userCookie	2	0
☐	> strv-mok-lt-06	device	has credentials of	user	2	0
☐	> strv-mok-lt-06	device	contains	entra-userCookie	2	0
☐	> mgmt1.2linkit.local	microsoft.compute/virtuali	contains	azure-storage-connection	2	0
☐	> dons-ekn-dt-01	device	contains	entra-userCookie	2	0
☐	> dc1.2linkit.local	microsoft.compute/virtuali	can authenticate as	managedidentity	1	0
☐	> dons-ekn-lt-02	device	has credentials of	user	1	0
☐	> dons-ekn-lt-02	device	frequently logged in by	user	1	0
☐	> dons-ekn-dt-01	device	has credentials of	user	1	0
☐	> mgmt1.2linkit.local	microsoft.compute/virtuali	contains	azure-database-connectio	1	0
☐	> strv-acw-dt-04	device	has credentials of	user	1	0
☐	> strv-acw-dt-04	device	frequently logged in by	user	1	0

Demo 9: Assets impacted by the same finding

Show shared exposure clusters: “this one finding impacts these assets”



```
let Nodes = ExposureGraphNodes | project NodeId, NodeName, NodeLabel, Categories;
```

```
let Findings =
```

```
    Nodes
```

```
    | where toString(Categories) has "finding"
```

```
    | project FindingId=NodeId, FindingName=NodeName;
```

```
let Assets =
```

```
    Nodes
```

```
    | where NodeLabel !has "finding"
```

```
    | project AssetId=NodeId, AssetName=NodeName, AssetLabel=NodeLabel;
```

```
let AffectingEdges =
```

```
    ExposureGraphEdges
```

```
    | where toString(EdgeLabel) has "affecting"
```

```
    | project SourceNodeId, TargetNodeId, EdgeLabel;
```

```
AffectingEdges
```

```
| join kind=inner (Findings) on $left.SourceNodeId == $right.FindingId
```

```
| join kind=inner (Assets) on $left.TargetNodeId == $right.AssetId
```

```
| summarize AssetCount=dcount(AssetId), ImpactedAssets=make_set(AssetName) by FindingName
```

```
| order by AssetCount desc
```

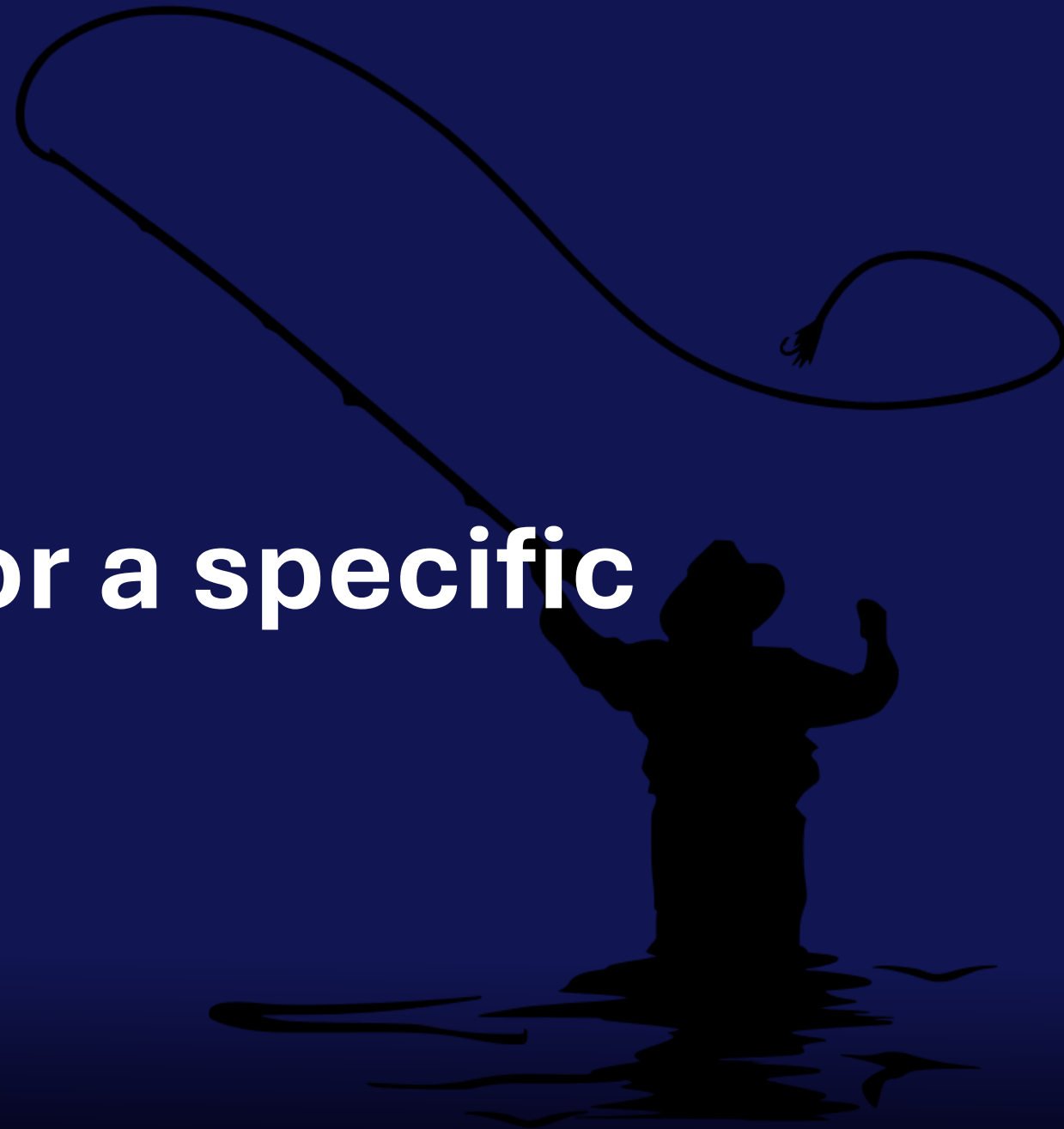
Filters: Add filter

☐	FindingName  	AssetCount  	ImpactedAssets  
☐	> SigninRiskPolicy	28	["LogicApp Connector Service Account, Azure WestEurope [DEMO]","svc-backup-keepit","F
☐	> MfaRegistrationV2	15	["LogicApp Connector Service Account, Azure WestEurope [DEMO]","Morten Knudsen (Ma
☐	> CVE-2025-69419	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-69420	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-69421	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-15467	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-68160	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2026-22795	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-9230	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2026-22796	14	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-66199	13	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi
☐	> CVE-2025-9231	13	["strv-mew-lt-02","usami-tom-lt-01","strv-mok-lt-06","strv-mok-dt-03","tomsdesktop","doi

Demo 10:

Show all Edges for a specific user

Can Authenticate As
Can Authenticate To
Frequently Logged in By
Can Impersonate As
Has Role On
Has Credentials Of
MemberOf



```
let userUPN = "caroline@waltorp.dk";
```

```
let userNodeId =
```

```
  ExposureGraphNodes
```

```
  | where NodeLabel == "user"
```

```
  | extend p = todynamic(NodeProperties)
```

```
  | where toString(p.rawData.accountUpn) =~ userUPN
```

```
  | project NodeId
```

```
  | take 1;
```

```
ExposureGraphEdges
```

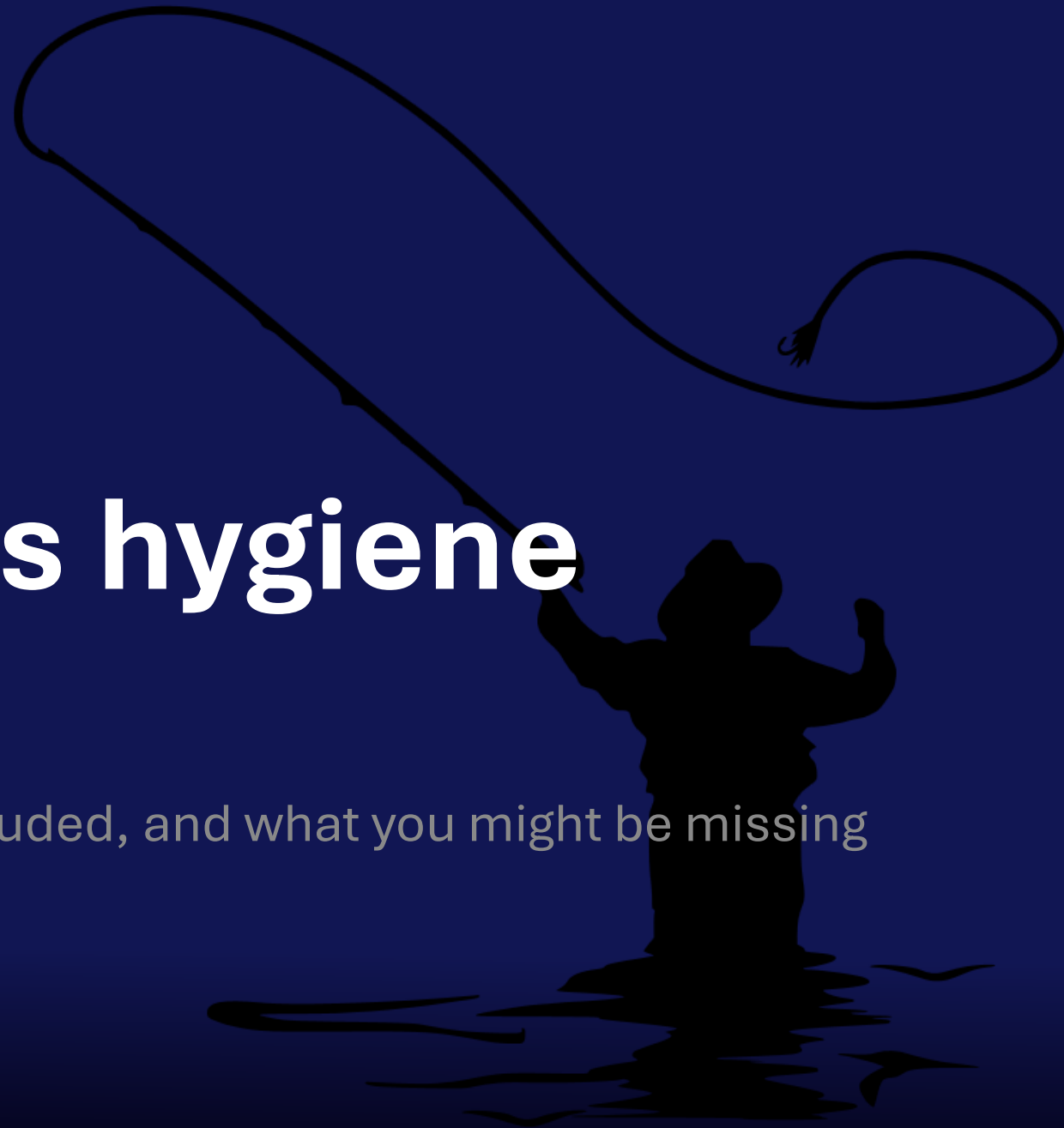
```
| where SourceNodeId in (userNodeId) or TargetNodeId in (userNodeId)
```

```
| sort by EdgeLabel asc
```

EdgeLabel	SourceNodeId	SourceNodeName	SourceNodeLabel	SourceNodeCategories	TargetNodeId	TargetNodeName	TargetNodeLabel	TargetNodeCategories
can authenticate as	29322e0919e64318a5a9f2	a5d6a2881db2ddfd40e3	entra-userCookie	["cookies","secret"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
can authenticate to	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]	69e43cfad61c4f9e883f0e4	strv-cew-lt-03	device	["compute","device","physical_device"]
can impersonate as	6a9d29318bf54dc199a61d	623256f8-5e9d-4b6e-a7bd	serviceprincipal	["application_identity","environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
can impersonate as	0a79d5f361894fe0aa7fa3a	468d666b-eb27-4702-936	serviceprincipal	["application_identity","environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
can impersonate as	095ecf84fcb7465ca94fdf9f	48c72940-ab0e-4ac6-b9fe	serviceprincipal	["application_identity","environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
can impersonate as	d71ea0af0773471ea2609f	e4d9397a-4581-4c4b-9dd	serviceprincipal	["application_identity","environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
can impersonate as	7c77123c5eb840f9ac3e78	7c0a0d12-af69-4102-a552	serviceprincipal	["application_identity","environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
frequently logged in by	69e43cfad61c4f9e883f0e4	strv-cew-lt-03	device	["compute","device","physical_device"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
has credentials of	69e43cfad61c4f9e883f0e4	strv-cew-lt-03	device	["compute","device","physical_device"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
has credentials of	83a9db5ed32246128507a	strv-mok-lt-06	device	["compute","device","physical_device"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
has permissions to	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]	465e0127aac5495194cc83	Windows Azure Active Directory	Microsoft Entra OAuth App	["application_identity","identities","identity"]
has permissions to	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]	f66ecc7e3d2f434b9ae156	Office 365 Exchange Online	Microsoft Entra OAuth App	["application_identity","identities","identity"]
has permissions to	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]	0b9459787ce54d2c83a81e	Microsoft Graph	Microsoft Entra OAuth App	["application_identity","identities","identity"]
has role on	5bc780aef54d4eb0a2a953	Enterprise Key Admins	group	["environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]
has role on	762ad8b42cfe4db3bf64b2	Enterprise Admins	group	["environmentAzure","environmentCloud","identities","identity","user_account"]	6c932f8b47b24be28e9712	Caroline Waltorp	user	["environmentAzure","environmentCloud","identities","identity","user_account"]

Demo 11: Excluded assets hygiene check

Show governance: which assets are excluded, and what you might be missing because of it.



ExposureGraphNode

| extend IsExcluded = tobool(coalesce(NodeProperties.rawData.isExcluded, NodeProperties.raw.isExcluded))

| where IsExcluded == true

| summarize ExcludedCount=count() by NodeLabel

| order by ExcludedCount desc

ExposureGraphNode

| extend IsExcluded = tobool(coalesce(NodeProperties.rawData.isExcluded, NodeProperties.raw.isExcluded))

| extend NoderawData = todynamic(NodeProperties).rawData

| extend

deviceManualTags = iff(isnull(NoderawData.deviceManualTags), dynamic([]), todynamic(NoderawData.deviceManualTags)),

deviceDynamicTags = iff(isnull(NoderawData.deviceDynamicTags), dynamic([]), todynamic(NoderawData.deviceDynamicTags)),

tags = iff(isnull(NoderawData.tags.tags), dynamic([]), todynamic(NoderawData.tags.tags))

| extend _AllTags = array_concat(array_concat(deviceManualTags, deviceDynamicTags), tags)

| extend AssetTags = strcat_array(_AllTags, ";")

| extend _TierTags = extract_all(@"([^\;]*--tier[0-3]--SI[^\;]*)", AssetTags)

| extend AssetTierByTag = strcat_array(array_sort_asc(coalesce(_TierTags, dynamic([]))), ";")

| extend NodeAssetTags = _AllTags

| where (AssetTags has "--Excluded--SI") or (IsExcluded == true)